Fpt University

TRƯỜNG ĐẠI HỌC FPT

CAPSTONE PROJECT REPORT

Report 3 – Software Requirement Specification

– Ho Chi Minh, October 2026 –

Table of Contents

I. Record of Changes....3
II. Software Requirement Specification....4
1. Product Overview....4
2. User Requirements....5
2.1 Actors....5
2.2 Use Cases....6
3. Functional Requirements....9
3.1 System Functional Overview....9
3.2 <<Feature Name 1>>....19
3.3 <<Feature Name 2>>....19
4. Non-Functional Requirements....21
4.1 External Interfaces....21
4.2 Quality Attributes....21
5. Requirement Appendix....22
5.1 Business Rules....22
5.2 Common Requirements....39
5.3 Application Messages List....40
5.4 Other Requirements....47

I. Record of Changes

Date	A* M, D	In charge	Change Description
06/10/2026	A	Nguyen Anh Hao	First draft of the access-control part: actors, use cases, screens, screen authorization, non-screen functions, business rules and messages.
20/10/2026	M	Nguyen Anh Hao	Area types merged into Public, Confidential and Highly Confidential ; configurable reason length; assignments revoked when an account is deactivated.
22/10/2026	M	Nguyen Anh Hao	The two review screens (access requests, guest visits) joined as the two tabs of Request Approval.
24/10/2026	M	Nguyen Anh Hao	Review blocked once a request has started (BR-RQ-48); system job finishes elapsed approved requests (BR-RQ-49); one assignment record per grant, validity no longer editable (BR-AP-28..30); event mode opened only by schedules (BR-EV-A7).
26/10/2026	A	Nguyen Anh Hao	added product overview, context diagram, ERD, external interfaces, quality attributes, common requirements and legal and compliance requirements.

*A - Added M - Modified D - Deleted

II. Software Requirement Specification

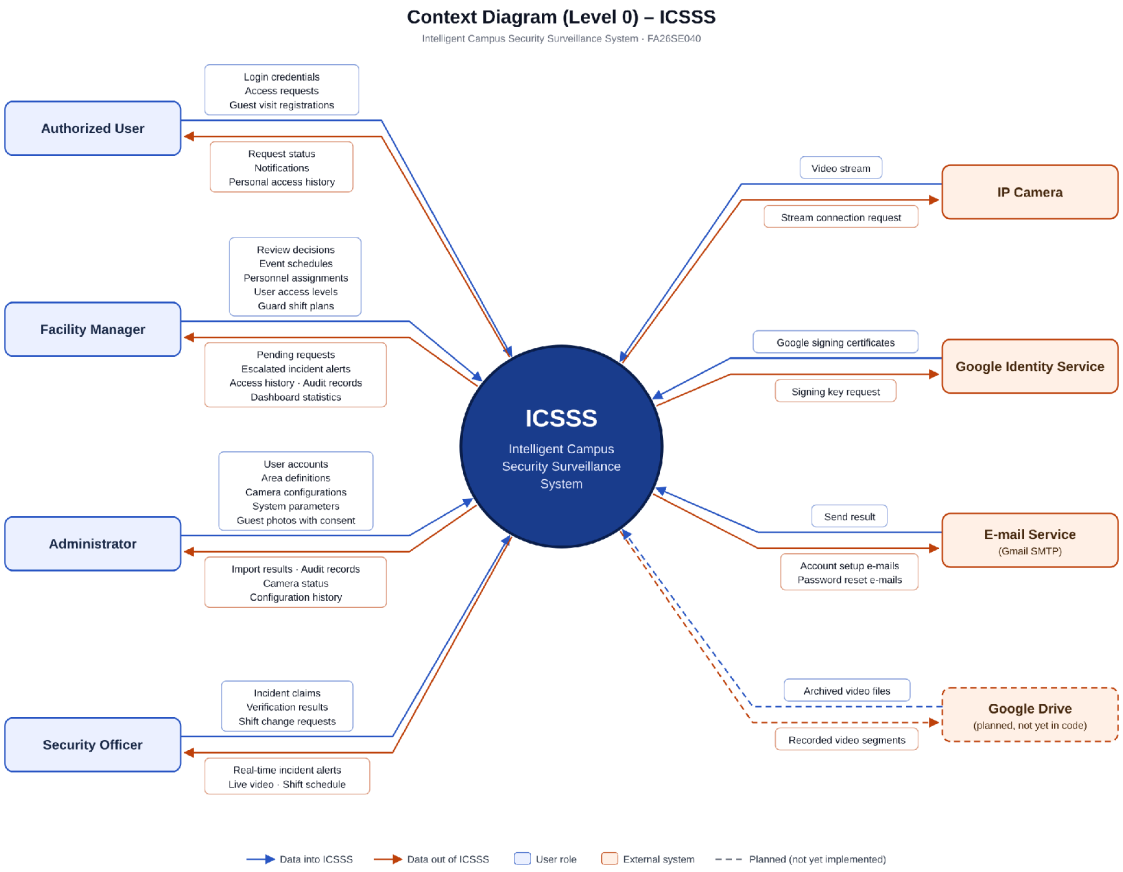
1. Product Overview

The Intelligent Campus Security Surveillance System (ICSSS) supports the security team and the facility management of FPT University, Tân Uyên campus, in controlling access to restricted areas such as laboratories, the data center, server rooms, electrical rooms and construction zones. Today these areas are watched by guards and by cameras that are checked by hand, so intrusions are easy to miss and the response is slow.

IP cameras stream video into the system. The AI Surveillance Engine (the ai-service) detects people, matches faces against registered users and approved guests, and asks the backend whether each recognised person may be in the camera's area at that time. The backend decides from the access sources — assigned personnel, the user's access level, a running event, the incident response of a Guard and an approved access request; for guests, an approved guest visit — and writes the decision to the camera access log. Denied or unknown persons lead to security incidents, which Security Officers claim, verify or dismiss on the web Security Monitoring Center and in the mobile app.

Around this core, Facility Managers review access requests and guest visits, assign named personnel, set user access levels and book events; Administrators manage accounts, areas, cameras and system parameters; and every user receives in-app notifications. Every business parameter (limits, lead times, retention, AI thresholds) is stored in System Configuration and takes effect without restart.

The context diagram below shows the system boundary. The Google Drive archive (dashed) is planned for video recording and is not implemented yet.



2. User Requirements

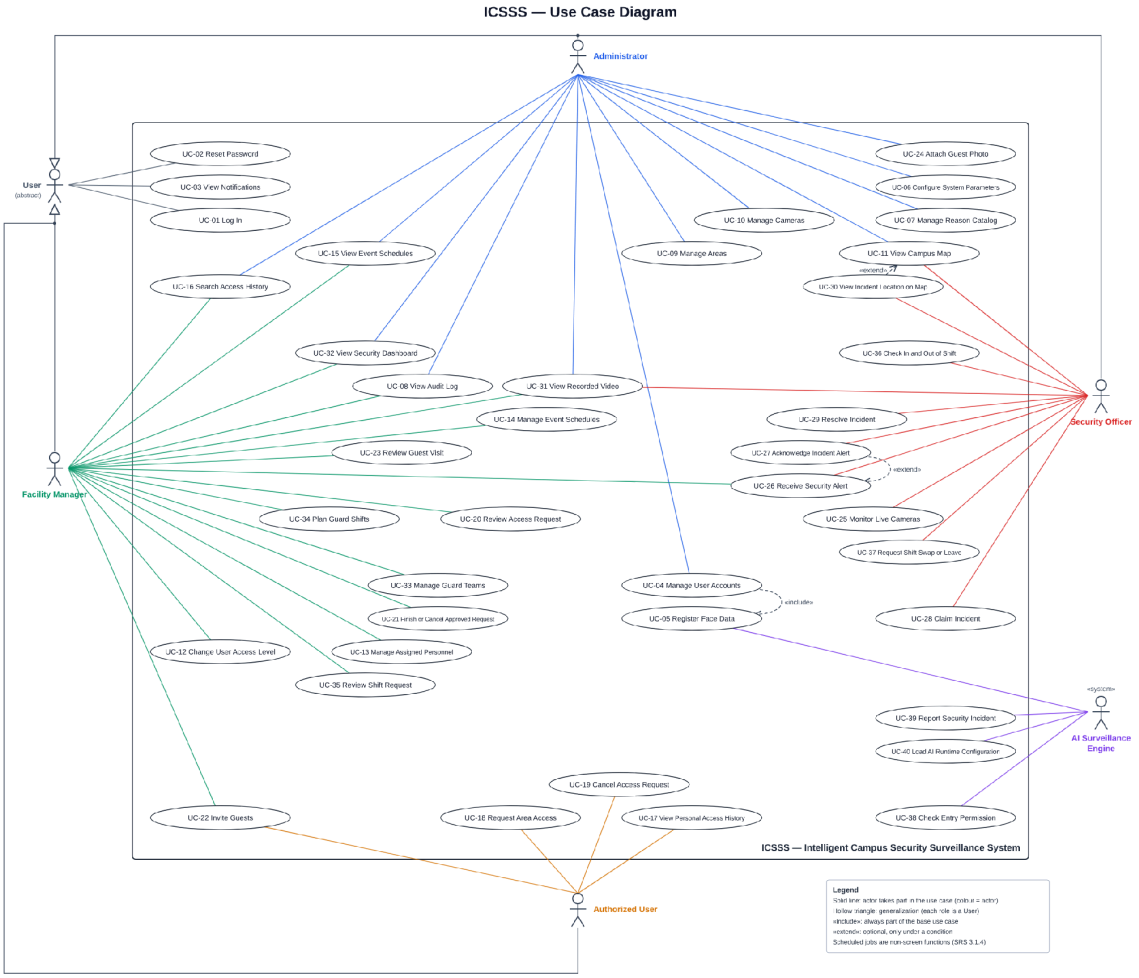
2.1 Actors

#	Actor	Description
1	User	Abstract actor: any person with an active account. Administrator, Facility Manager, Authorized User and Security Officer are specialisations of User and inherit its use cases (UC-01 to UC-03).
2	Administrator	Manages master data and settings: user accounts and face data, areas, cameras, system parameters, the reason catalog and guest photos. Views the audit log, event schedules, access history, recorded video, the campus map and the security dashboard.
3	Facility Manager	Operates daily access control: changes user access levels, assigns personnel to areas, manages event schedules, reviews access requests and guest visits, manages guard teams and shifts. Receives escalated security alerts and views the audit log, access history, recorded video and the security dashboard. May invite guests.
4	Authorized User	A campus member without a management role (student or staff). Requests and cancels access to restricted areas, invites guests and views own access history.
5	Security Officer	On-duty guard. Monitors live cameras, receives and acknowledges security alerts, claims and resolves incidents (verifies or dismisses the AI result), views the campus map and recorded video, checks in and out of shifts and requests shift swaps or leave.
6	AI Surveillance Engine	External system that analyses camera streams and extracts face embeddings from registration photos (UC-05). Asks the system whether a recognised person may enter an area, reports security incidents and loads its runtime parameters from the system configuration.

Note: time-based jobs (expiry, auto-finish, escalation, reminders) are non-screen functions described in section 3.1.4, not actors. The e-mail service and Google sign-in are external services used inside UC-01 and UC-02 and are not drawn as actors. Guests are not actors: they do not log in; the host registers them and the Administrator attaches their photo.

2.2 Use Cases

2.2.1 Diagram(s)



Relationships between use cases:

Base use case	Relationship	Use case	Reason
UC-04 Manage User Accounts	«include»	UC-05 Register Face Data	Creating or importing an account always registers its face photo.
UC-27 Acknowledge Incident Alert	«extend»	UC-26 Receive Security Alert	Acknowledgement happens only when an alert has been received and the guard chooses to confirm it.
UC-30 View Incident Location on Map	«extend»	UC-11 View Campus Map	The map opens with a route only when the guard navigates to an incident.

2.2.2 Descriptions

ID	Use Case	Actors	Use Case Description
UC-01	Log In	User	Log in with e-mail and password or with a Google account whose e-mail matches an active account; only active accounts can log in. The user is redirected by role and can log out.
UC-02	Reset Password	User	Request a single-use password reset link by e-mail and set a new password with it.

UC-03	View Notifications	User	List one's in-app notifications with the unread count, open the related request or visit, and mark one or all notifications as read.
UC-04	Manage User Accounts	Administrator	Create one account with a face photo, or many accounts from a ZIP file where each row succeeds or fails independently; activate, deactivate or delete accounts; remove or restore an import batch. Deactivating or deleting an account cancels the user's active access requests and closes the user's open sessions. Always includes UC-05.
UC-05	Register Face Data	Administrator (through UC-04), AI Surveillance Engine	Check that the photo is JPG or PNG and at most 350 KB; the AI Surveillance Engine detects the face and extracts a 512-dimension embedding; the photo is rejected unless exactly one face is found; the photo and the embedding are stored for the account.
UC-06	Configure System Parameters	Administrator	View and change business parameters (for example AI thresholds, escalation minutes, retention periods) with a reason. A change takes effect without restart and its history keeps the old value, new value, actor and reason.
UC-07	Manage Reason Catalog	Administrator	Add, edit, hide or re-enable the reasons used in event operations; the "Other" reason must stay active.
UC-08	View Audit Log	Administrator, Facility Manager	Browse the audit records of the modules allowed for one's role, with filters and pagination.
UC-09	Manage Areas	Administrator	Create and edit areas; change an area's type with a reason after a preview of its effects; deactivate an area after checking its blockers (assigned cameras, open incidents, running events) and restore it. The access level is fixed by the type: Public 1, Confidential 2, Highly Confidential 3.
UC-10	Manage Cameras	Administrator	Register and edit cameras, assign them to areas, set the stream and the detection region (ROI), and decommission or reactivate a camera.
UC-11	View Campus Map	Administrator, Security Officer	View the campus areas on the map: on the web application for the Administrator and on the mobile application for the Security Officer.
UC-12	Change User Access Level	Facility Manager	Search active users and change the access level (1 to 3) of one user or of several selected users at once, with a reason; a

			Facility Manager cannot change their own level.
UC-13	Manage Assigned Personnel	Facility Manager	Assign a named user to a restricted area for one validity window (one record per grant), grant the next window, or revoke an active or upcoming assignment with a reason.
UC-14	Manage Event Schedules	Facility Manager	Book, edit or cancel an event for a Confidential area and stop a running event; each action requires a reason from the catalog. The area is open to all members only while the event runs.
UC-15	View Event Schedules	Administrator, Facility Manager	List the event schedules of all areas with search and filters.
UC-16	Search Access History	Administrator, Facility Manager	Search the camera access records of everyone by area, person code, result and date range.
UC-17	View Personal Access History	Authorized User	List one's own camera access records (allowed and denied) for a date range.
UC-18	Request Area Access	Authorized User	Request entry to a restricted area for a time window, alone or as a group; member codes are checked before submission.
UC-19	Cancel Access Request	Authorized User	View one's own access requests and cancel a pending one.
UC-20	Review Access Request	Facility Manager	Approve or reject (with a reason) a pending access request before its start time, after re-checking the current rules.
UC-21	Finish or Cancel Approved Request	Facility Manager	Finish an approved request that has started, or cancel an approved request that has not started, with a reason; participants are notified.
UC-22	Invite Guests	Authorized User, Facility Manager	As host, register guests to visit one or more Confidential areas within a time window, view one's visits and cancel a visit that has not ended.
UC-23	Review Guest Visit	Facility Manager	Approve or reject a pending guest visit, or revoke an approved one; the host cannot review their own visit. Revoking deletes the guests' biometric data.
UC-24	Attach Guest Photo	Administrator	Attach a consented face photo to each guest of an approved visit and view a guest photo through a short-lived link; every view is audited.
UC-25	Monitor Live Cameras	Security Officer	Watch live camera streams; an offline camera shows a "signal lost" state.
UC-26	Receive Security Alert	Facility Manager, Security Officer	The on-duty Security Officer receives a real-time alert when an incident is created; the Facility Manager is notified when an incident is not claimed within the configured time.

UC-27	Acknowledge Incident Alert	Security Officer	Confirm that a received alert has been seen; this stops the evidence recording of the incident. Extends UC-26.
UC-28	Claim Incident	Security Officer	Take ownership of a new incident so that no other guard handles it.
UC-29	Resolve Incident	Security Officer	Resolve a claimed incident as Verified or Dismissed with a note; only the guard who claimed it can resolve it. This is how a person verifies the AI result.
UC-30	View Incident Location on Map	Security Officer	From the incident list, open the campus map with the route to the area of the incident. Extends UC-11.
UC-31	View Recorded Video	Administrator, Facility Manager, Security Officer	View recorded camera video and incident video.
UC-32	View Security Dashboard	Administrator, Facility Manager	View read-only security statistics for a chosen period: incidents by status, dismissed rate, the five areas with most incidents and access attempts per day by result.
UC-33	Manage Guard Teams	Facility Manager	Create guard teams, add members and move members between teams.
UC-34	Plan Guard Shifts	Facility Manager	Create shifts for guard teams, edit shifts and export attendance.
UC-35	Review Shift Request	Facility Manager	Approve or reject a Security Officer's request to swap a shift or take leave.
UC-36	Check In and Out of Shift	Security Officer	View one's own shifts on the mobile application and check in and out.
UC-37	Request Shift Swap or Leave	Security Officer	Request to swap a shift with another guard or to take leave.
UC-38	Check Entry Permission	AI Surveillance Engine	For each recognised person (user or guest), ask whether the person may enter the area at that time; the answer is recorded in the access history.
UC-39	Report Security Incident	AI Surveillance Engine	Send an alert with a timestamp and a snapshot when an unauthorised entry is detected; the system creates a new incident.
UC-40	Load AI Runtime Configuration	AI Surveillance Engine	Load the recognition thresholds and time settings from the system configuration, so that changes made in UC-06 apply without restart.

3. Functional Requirements

3.1 System Functional Overview

3.1.1 Screens Flow

[Screens flow diagram to be inserted (web and mobile). Screens of the access-control part are listed in 3.1.2.]

3.1.2 Screen Descriptions

#	Feature	Screen	Description

1	Authentication	Login	Entry screen with two tabs: "Google Mail" (Google sign-in) and "Account" (e-mail + password). Links to the password reset mode. After login the user is redirected to the Dashboard, or to Access Requests for an Authorized User.
1.1	Authentication	Password Recovery (mode of Login)	Enter the account e-mail to receive a reset link.
1.2	Authentication	Reset Password (mode of Login)	Open from the e-mailed link; enter and confirm a new password.
2	Authentication	Unauthorized	Shown when a logged-in user opens a screen not allowed for their role; offers a link back to the home screen.
3	Area	Area Management	Lists areas by building and floor (type, access level fixed by type, event state, cameras). Administrator: create, edit, change type, deactivate, manage area cameras. Facility Manager: assigned personnel; the count of booked schedules on an area card opens Event Management filtered to that area and to SCHEDULED (PR #118); the "change access level" action is not shown to the Facility Manager.
3.1	Area	Create Area (popup)	Name, area type, building and floor, optional centre coordinates.
3.2	Area	Edit Area (popup)	Same fields as Create Area plus a reason when the type changes.
3.3	Area	Area Type Change Preview (popup)	Shows the new access level and flag, requests that will be cancelled, pending requests that will not be approvable, active assignments, and blocking reasons; confirm or go back.
3.4	Area	Deactivate Area (popup)	Shows blockers and the number of assignments, requests and guest visits that will be handled; requires a reason.
3.5	Area	Restore Area (popup) and "Deactivated areas" tab	Administrator: the "Deactivated areas" tab lists deactivated areas; the popup reactivates one with a reason (10–500 characters).
3.6	Area	Area Cameras (popup)	Lists the cameras of an area; the Administrator can remove a camera from the area.
3.9	Area	Assigned Personnel (popup)	Lists named users assigned to the area by status (active, upcoming, expired, revoked); assign a user for one validity period, "Next grant" on Active and Expired rows with an end time (pre-fills the user and the start time), revoke an Active or Upcoming assignment with a reason. The validity of an existing assignment cannot be edited.
4	Access Level	User Access Levels	Facility Manager: the list of active users loads (page 1, 20 per page) when the screen opens; optional keyword and current-level filter. Change one user's level with a reason (popup "Confirm access level change"), or tick several users (kept across pages; one's own row cannot be ticked) and change their level together in the bulk popup, which shows the result per user (updated / unchanged / failed).

6	Access Request	Access Requests	Authorized User: "New access request" form (individual or group, area, date and time, purpose, member codes with suggestions) and the "My requests" table with status and area filters, details and cancel.
6.1	Access Request	Access Request Details (popup)	Area, time window, purpose, members, status, reviewer and rejection reason.
6.2	Access Request	Cancel Access Request (popup)	Confirm cancellation of a pending request.
7	Access Request	Request Approval — tab "Access requests"	Facility Manager, menu "Request Approval" (PR #123; the screen joins the former Request Approval (Access requests tab) and Request Approval (Guest visits tab) as two tabs, ?tab=requests is the default; switching tabs keeps the tab in the address and clears the other tab's requestId / visitId; the Refresh button sits on the tab bar): all requests with status tabs that show the count of each status (All, Pending — highlighted when > 0, Approved, Rejected, Cancelled, Expired, Finished; the former row of statistic tiles is removed) and an area filter; approve, reject, view details; on an APPROVED request, "Finish" once it has started or "Cancel" before it starts. Opened from a notification, it highlights or opens the referenced request. Finished requests show the finish reason and the Facility Manager who finished them (V88).
7.1	Access Request	Approve Request (popup)	Confirm approval.
7.2	Access Request	Reject Request (popup)	Enter a rejection reason (10–500 characters).
7.3	Access Request	Finish Request (popup)	Enter the reason (10–500 characters) for moving a started APPROVED request to Finished.
7.4	Access Request	Cancel Approved Request (popup)	Enter the reason (10–500 characters) for cancelling an APPROVED request that has not started.
8	Guest Visit	My Guest Visits	Authorized User and Facility Manager (not the Administrator): host lists own visits; creates a visit ("Create guest visit" popup: guests, purpose, areas, time) and cancels a visit with an optional reason. "Create guest visit" is hidden, with a warning showing the required and current level, when the caller's level is below the minimum host level. An APPROVED visit with guests still without a photo shows "No photo yet (x/y guests)" and "Guests must register their face at the desk before the visit".

9	Guest Visit	Request Approval — tab "Guest visits"	Facility Manager (?tab=guests; the former address /admin/guest-visits redirects here and keeps visitId; the GUEST_VISIT_PENDING notification opens this tab): all visits by status; details, approve, reject (reason) and revoke (reason). In the details popup the action buttons are shown only when the Facility Manager is not the host (otherwise a note explains why); without actions, only "Close" is shown. APPROVED visits with guests without a photo show "No photo yet (x/y guests)".
10	Guest Visit	Guest Photos	Administrator: approved visits and their guests, labelled "No photo yet (x/y guests)" while guests are missing a photo; "Attach guest photo" popup (consent confirmation for the current notice version + JPG/PNG file) and "View guest photo" popup (temporary link).
11	Account	Account Management	Administrator: tabs "Authorized users" and "System accounts" with search, active filter and pagination; create account, activate / deactivate, delete, bulk import from ZIP, import batch history.
11.1	Account	Create Account (popup)	Full name, user code, e-mail, role (system accounts) and face photo.
11.2	Account	Bulk Import (popup)	Upload a ZIP, download the template, confirm, and view the per-row result.
11.3	Account	Import Batches (popup)	List of batches; batch details; remove or restore a batch and view the restore result.
12	Notification	Notifications	The user's notifications, newest first, 20 per page; clicking one marks it read and opens the related request or guest visit (the target screen highlights the row or opens its details popup); "mark all as read". The unread count is shown on the sidebar bell.
13	Reason Catalog	Reason Catalog	Administrator: reasons grouped by event action type; add, edit label / order, deactivate or reactivate (the "Other" item cannot be deactivated).
14	System Configuration	System Configuration	Administrator: parameters grouped by category with value controls by data type and allowed range; "Confirm configuration update" popup with a reason; "Configuration change history" popup.
15	Audit Log	Audit Log	Administrator and Facility Manager: audit records of the modules allowed for the role with filters (module, target type, area, performed by, affected user, date range, "same operation"), old → new values, reasons and pagination.
16	Access History	Access History (my history)	Authorized User (menu "Access History", /access-history): one's own camera access records, newest first, 20 per page — time, area, camera, result, reason — with a from / to date filter (default: last 7 days).

16.1	Access History	Access History (all)	Facility Manager and Administrator (/admin/access-history): camera access records of everyone, newest first, 20 per page — time, person (code and full name; Stranger / Unidentified for unknown codes), area, camera, result, reason — with area, person code, result and from / to date filters (default: last 7 days).
18	Dashboard	Dashboard	Administrator, Facility Manager and Security Officer (/dashboard; the Authorized User is sent to Access Requests): summary cards (areas by type, active cameras, open incidents for Administrator and Security Officer, active accounts for Administrator, recent audit records for Administrator and Facility Manager). Section "Security statistics" for Facility Manager and Administrator: period selector (Today / 7 days / 30 days, kept in ?statsRange=), four incident counts by status, dismissed rate "on N concluded incidents", top 5 areas by incident count, stacked bar chart of access attempts per day by result; loading, error (Retry) and empty states.
17	Event	Event Management	Facility Manager and Administrator (menu "Event Management", PR #118): one table of event schedules of all areas — event name, area, start – end, type, status, created by, actions — with search (event name or area), status, area and date filters, Clear filters and Refresh. Facility Manager: Create Event; Edit and Cancel on a SCHEDULED event; Stop on a STARTED event. Administrator: view only. Change history is read in the Audit Log.
17.1	Event	Create / Edit Event (popup)	Event name (1–150 characters), Confidential area, start and end time, reason, optional note when creating (10–500 characters if entered); when editing, the note is mandatory and records the reason for the edit.
17.2	Event	Cancel Event (popup)	Reason and note (10–500 characters) for cancelling a SCHEDULED event.
17.3	Event	Stop Event (popup)	Reason and optional note for ending a STARTED event now (event-mode DISABLE).
17.4	Event	Event Details (popup)	Name, area, time window, type, status (with the failure reason for FAILED), note, created by, last edited by, cancelled by.

3.1.3 Screen Authorization

Screen	Operation	Administrator	Facility Manager	Security Officer	Authorized User
Area Management	Query All	X	X		
Area Management	Add	X	X		
Area Management	Update	X	X		
Area Management	Delete	X	X		
User Access Levels	Query All		X		
User Access Levels	Update		X		

Access Requests	Query Own				X
Access Requests	Add				X
Access Requests	Delete				X
Request Approval — Access requests tab	Query All		X		
Request Approval — Access requests tab	Update		X		
My Guest Visits	Query Own		X		X
My Guest Visits	Add		X		X
My Guest Visits	Delete		X		X
Request Approval — Guest visits tab	Query All		X		
Request Approval — Guest visits tab	Update		X		
Request Approval — Guest visits tab	Delete		X		
Guest Photos	Query All	X			
Guest Photos	Add	X			
Guest Photos	Update	X			
Account Management	Query All	X			
Account Management	Add	X			
Account Management	Update	X			
Account Management	Delete	X			
Notifications	Query Own	X	X	X	X
Notifications	Update	X	X	X	X
Reason Catalog	Query All	X			
Reason Catalog	Add	X			
Reason Catalog	Update	X			
Reason Catalog	Delete	X			
System Configuration	Query All	X			
System Configuration	Update	X			
Audit Log	Query Managed	X	X		
Event Management	Query All	X	X		
Event Management	Add		X		
Event Management	Update		X		
Event Management	Delete		X		
Dashboard	Query All	X	X	X	
Access History	Query All	X	X		
Access History	Query Own				X

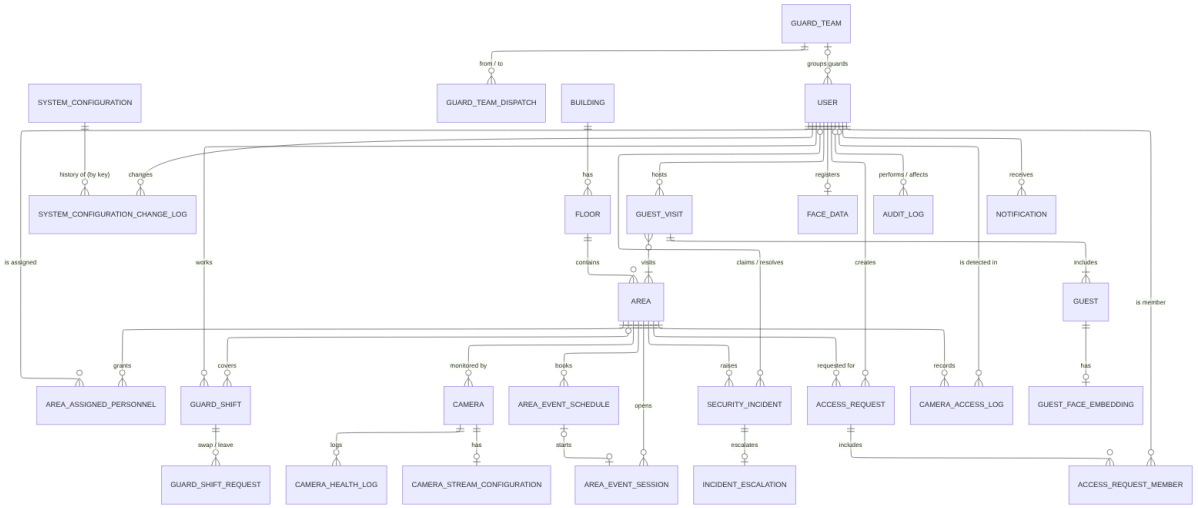
3.1.4 Non-Screen Functions

#	Feature	System Function	Description
NSF-01	Access Request	Expire Overdue Access Requests	Runs every 15 minutes (expire-overdue-cron, 0 */15 * * * *). Locks every pending request whose start time has passed and sets it to Expired; the batch is aborted if the number of updated rows differs from the number locked. Writes an EXPIRE audit record with actor System (EXPIRE_OVERDUE_REQUESTS_JOB) and, after commit, sends an ACCESS_DENIED notification to the requester. BR-RQ-43.
NSF-02	Notification	Notify Requests Starting Soon	Runs every 10 minutes (notification-expiring-soon-cron). Finds approved requests that start within the configured lead time (NOTIFICATION_EXPIRING_SOON_LEAD_MINUTES, ± 5 minutes) and sends one EXPIRING_SOON notification to the requester and each member; a request already notified is skipped. BR-NT-22.
NSF-03	Notification	Notify Overdue Pending Requests	Runs every hour (notification-pending-overdue-cron). Finds requests pending for longer than NOTIFICATION_PENDING_OVERDUE_HOURS and sends one PENDING_OVERDUE notification per request to every active Facility Manager. BR-NT-23.
NSF-04	Area — Event Mode	Event Mode Tick	Runs every minute (event-mode-tick-cron). (a) Closes event mode sessions whose end time has passed; (b) activates scheduled event schedules that are due, or marks them Failed when they cannot start; (c) sends schedule-starting reminders. Each item runs in its own transaction. Writes audit records with actor System and sends EVENT_MODE_CHANGED (Guards), EVENT_MODE_SCHEDULE_FAILED and EVENT_MODE_SCHEDULE_STARTING (Facility Managers) notifications. BR-EV-28, BR-ES-17, BR-ES-27, BR-ES-28.
NSF-05	Area — Event Mode	Remind Event Mode Expiry	Runs every minute (default declared only in the annotation; the key is not in application.yml). Finds active sessions that end within the reminder lead time (EVENT_MODE_EXPIRY_REMINDER_MINUTES; 0 disables reminders) and sends one EVENT_MODE_EXPIRING notification to the Facility Manager who started the session if still active, otherwise to all active Facility Managers; records the reminder time so it is sent once. BR-EV-29.
NSF-06	Guest Visit	Guest Visit Tick	Runs every minute (guest-visit-tick-cron). Expires pending visits at their start time, completes approved visits at their end time, deletes guest biometric data when due, retries photo deletions that failed earlier, anonymises old guest records, and reminds Administrators about missing guest photos: an APPROVED visit that starts within GUEST_PHOTO_REMINDER_MINUTES_BEFORE (default 60 minutes, range 5–1440, group GUEST) and still has guests without PHOTO_READY triggers one GUEST_PHOTO_REQUIRED to every active Administrator (skipped if one was already sent for the visit since the window start). Each item is locked and processed in its own transaction with actor System (GUEST_VISIT_JOB). Writes EXPIRE / COMPLETE / DELETE_BIOMETRIC / ANONYMIZE audit records, sends GUEST_VISIT_EXPIRED to the host and deletes photo objects from file storage. BR-GV-12, BR-GV-25, BR-GV-27, BR-GV-29, BR-GV-39.

#	Feature	System Function	Description
NSF-07	Access Request	Clean Up Member Lookup Counters	Runs every 5 minutes (default declared only in the annotation). Removes in-memory lookup timestamps older than 5 minutes from the member lookup rate limiter. Memory only, single instance.
NSF-08	System	Set Default Time Zone	At start-up, sets the application default time zone to Asia/Ho_Chi_Minh.
NSF-09	System Configuration	Load Configuration Cache	At start-up, loads every row of system_configurations into the in-memory cache. The Administrator can reload the cache manually (UC-CFG-04) after values were edited directly in the database; an update through the API takes effect without restart (BR-SC-25).
NSF-10	Authentication	Send Password Reset E-mail	Triggered by a password reset request (UC-AUTH-03). Sends, on the background mail executor, an e-mail with a reset link that contains a one-time token; the validity is PASSWORD_RESET_TOKEN_MINUTES (default 15) and the text states the same number of minutes. The link base address comes from the deployment setting app.frontend-base-url (BR-AU-36). The link and token are not logged.
NSF-11	Account	Send Account Setup E-mail	Triggered when an account is created singly (UC-ACC-02) or by bulk import (UC-ACC-03), after the account transaction has committed; sent on the background mail executor. Contains the full name, user code, e-mail and temporary password (HTML-escaped) and tells the user to use "Forgot password" to set their own password. A delivery failure does not roll back the account (BR-AU-06).
NSF-12	Access Request	Cancel Requests of Deactivated Requester	Triggered when an account is deactivated, deleted or removed with its import batch. Cancels every pending or approved, not-yet-ended request the user created, with a system reason and actor System, and notifies the members after commit (REQUEST_SYSTEM_CANCELLED). Reactivating the account does not restore the requests; deactivating a member does not change the request. BR-RQ-SP-05.
NSF-13	Area	Cancel Requests on Area Type Change or Deactivation	Triggered when an area changes type or is deactivated. In the same transaction, cancels the approved, not-yet-ended requests that no longer satisfy the new type (all pending and approved requests when the new type is Public, and all of them on deactivation), with a reason describing the violation. After commit, the requester and members of each cancelled request receive exactly one REQUEST_SYSTEM_CANCELLED notification. BR-TC-08, BR-TC-14, BR-TC-16, BR-AD-05.
NSF-14	Area — Assigned Personnel	Revoke Assignments on Area Deactivation	Triggered when an area is deactivated. Revokes every active and upcoming personnel assignment of the area with the deactivation reason, audits each revocation, and sends ACCESS_PERMISSION_REVOKED to each assignee after commit. BR-AD-04.
NSF-15	Guest Visit	Close Guest Visits of Deactivated Area	Triggered when an area is deactivated. Cancels the pending guest visits that include the area (the host receives GUEST_VISIT_CANCELLED_BY_SYSTEM) and revokes the approved ones; visits that have already ended or changed concurrently are skipped. BR-GV-37.
NSF-16	System Configuration	Notify Facility Managers of Event Limit Violations	Triggered when the Administrator changes EVENT_MODE_MAX_HOURS, EVENT_MODE_WINDOW_DAYS or EVENT_MODE_BUDGET_HOURS. After commit, lists the areas whose active session or scheduled event schedules

#	Feature	System Function	Description
			exceed the new limits and sends EVENT_MODE_LIMIT_CHANGED to every active Facility Manager; nothing is cancelled. BR-SC-27.
NSF-17	System Configuration	Push After-hours Window to AI Service	Triggered when the Administrator changes AI_AFTER_HOUR_START or AI_AFTER_HOUR_END. Sends the new window to the AI Service after commit; a failure is only logged. BR-SC-28.
NSF-18	System Configuration	Push AI Configuration at Start-up	Triggered once when the backend has started. Sends the after-hours window and the AI runtime parameters to the AI Service; the AI Service also pulls them from GET /api/internal/ai/runtime-config when it starts. A failure is only logged. BR-SC-30.
NSF-19	Access History	Delete Expired Camera Access Logs	Daily job (cron icss.scheduler.access-log-retention-cron). Deletes camera access log records older than ENTRY_LOG_RETENTION_DAYS; skipped when the value is below 1. BR-CE-05.
NSF-20	Incident Escalation	Escalate Unclaimed Incidents	Runs repeatedly; the next run starts INCIDENT_ESCALATION_CHECK_SECONDS (default 30) after the previous run ends, the value being read before each scheduling (no cron). Can be disabled only by the operational flag icss.scheduler.incident-escalation-enabled (off in the test profile). For every open escalation record: closes it when the incident has left NEW; otherwise, when the incident has waited INCIDENT_ESCALATE_FM_MINUTES or no guard was on duty at creation, sends INCIDENT_ESCALATED to every active Facility Manager plus a real-time message, once per incident. Each record is processed in its own transaction. BR-IE-03 … BR-IE-10.
NSF-21	Guard Mobile App	Keep Duty Alerts Running	Android foreground service "On duty", started while the logged-in guard has a CHECKED_IN shift and stopped when no shift is CHECKED_IN or on logout. Keeps the real-time connection alive in the background and shows a system notification for each new incident. BR-GN-01 … BR-GN-05.
NSF-22	Access Request	Finish Elapsed Approved Requests	Runs every 15 minutes (icss.scheduler.finish-elapsed-cron). Locks every APPROVED request whose end time has passed and sets it to Finished with the finish reason "Validity period ended" and no finisher; the batch is rolled back if the number of updated rows differs from the number locked. Writes one FINISH audit record per request with actor System. No notification is sent. BR-RQ-49.

3.1.5 Entity Relationship Diagram



Entities Description

#	Entity	Table	Description
1	User	users	Account of an Administrator, Facility Manager, Security Officer (GUARD) or Authorized User: user code, full name, e-mail, role, access level (1–3), active flag, soft delete.
2	Face Data	face_data	Face image reference and embedding of a user, registered when the account is created or imported.
3	Building, Floor	buildings, floors	Campus location hierarchy that areas belong to.
4	Area	areas	Restricted or public zone: name, type (Public, Confidential, Highly Confidential), access level fixed by the type, event flag, active flag, version for optimistic locking.
5	Access Request	access_requests	Individual or group request to enter an area in a time window; status PENDING, APPROVED, REJECTED, CANCELLED, EXPIRED or FINISHED with reviewer, cancel and finish details.
6	Access Request Member	access_request_members	Member of a group request; flags members sponsored below the area level.
7	Assigned Personnel	area_assigned_personnel	One grant of named access to an area for [validFrom, validTo); status (upcoming, active, expired, revoked) is computed when read.
8	Event Schedule	area_event_schedules	Booked event of a Confidential area: name, start, end, reason, status SCHEDULED, STARTED, COMPLETED, ENDED_EARLY, CANCELLED or FAILED.
9	Event Session	area_event_sessions	Period in which an area is actually open to all members; opened by a schedule, closed at the planned end or by Stop.
10	Guest Visit, Guest Visit Area	guest_visits, guest_visit_areas	Visit hosted by a user for one or more Confidential areas in a time window, reviewed by a Facility Manager.
11	Guest, Guest Face Embedding	guests, guest_face_embeddings	External visitor of a visit, consent record and biometric status; the embedding is deleted after retention.
12	Camera Access Log	camera_access_logs	Result of each camera entry check: camera, area, person, result, access source, reason, time.
13	Notification	notifications	In-app notification for one recipient with type, target and read flag.
14	Reason Catalog	reason_catalog	Reasons selectable for event actions, grouped by action type.

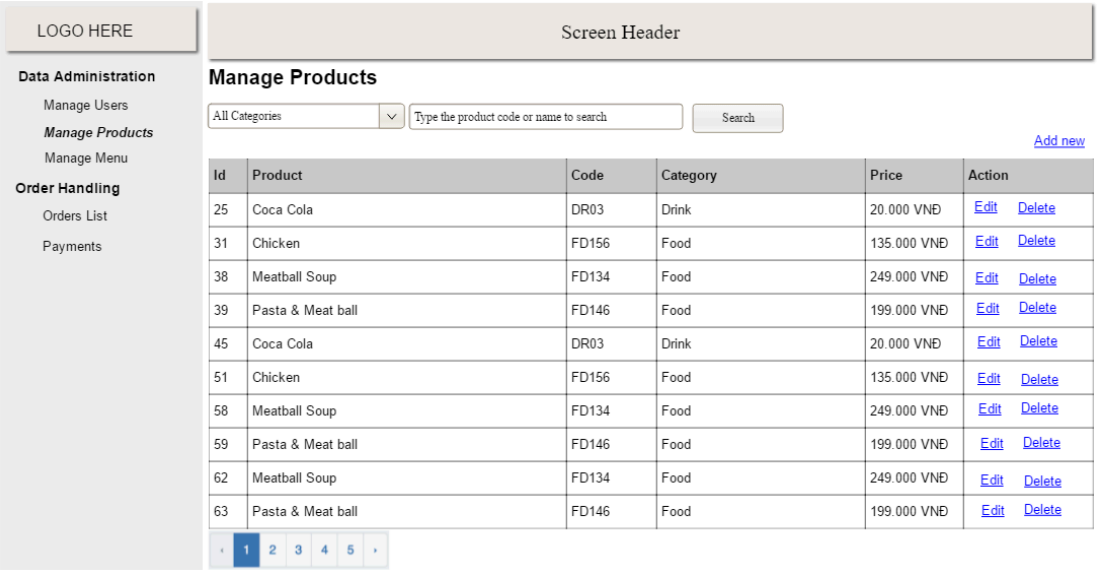
#	Entity	Table	Description
15	System Configuration, Change Log	system_configurations, system_configuration_change_logs	Business parameters with type and allowed range, and the history of every change with reason.
16	Audit Log	audit_logs	Append-only record of every business change with actor, target, old and new values and reason.
17	Password Reset Token	password_reset_tokens	One-time token for the password reset link.
18	Incident Escalation	incident_escalations	Escalation tracking of an unclaimed security incident to Facility Managers.
19	Camera, Stream Configuration, Health Log	cameras, camera_stream_configurations, camera_health_logs	Camera registered to one area, its stream settings and health history.
20	Security Incident	security_incidents	Incident raised from a detection, claimed and resolved (verified / dismissed) by a Security Officer.
21	Guard Team, Shift, Shift Request, Team Dispatch	guard_teams, guard_shifts, guard_shift_requests, guard_team_dispatches	Guard organisation, duty shifts, swap and leave requests, team moves.

3.2 <<Feature Name 1>>

3.2.1 <<Function Name 1>>

[A function can be a screen or a non-screen function (listed in the part 3.1.5 above). In this part, you need to provide the details on the related function, focus on mentioning below information

- *Function trigger: how this function is triggered (navigation path, a timing frequency, etc.*
- *Function description: actors/roles, purpose, interface, data processing, etc.*
- *Screen layout: mock-up prototype of the screen, sample below is for Manage Products screen*



- *Function Details: provide explanation for the data, validation, business rules, functionalities (for both normal cases and abnormal cases), etc. of the function so that the reader can image how it work.*

]

3.2.2 <<Function Name 2>>

…

3.3 <<Feature Name 2>>

…

4. Non-Functional Requirements

4.1 External Interfaces

#	Interface	Type	Protocol / format	Used for	Status
1	Web client (React)	User interface	HTTPS / REST + JSON, WebSocket	All screens of Administrator, Facility Manager, Security Officer, Authorized User	Implemented; TLS is a deployment requirement, not yet configured
2	Security Officer mobile app (Flutter, Android)	User interface	REST + JSON, WebSocket	Shifts, check-in / out, incident claim and resolve, duty alerts	Implemented
3	AI Service (FastAPI, YOLO11, ByteTrack, YuNet, ArcFace)	Internal service	REST + JSON with header X-Service-Key; Kafka events	Entry check, runtime configuration, face embeddings, incidents	Implemented; details by the AI owner
4	MinIO object storage	Software	S3 API, server-side encryption (SSE-S3)	Face images, guest photos, evidence snapshots	Implemented; files served only through the backend with permission checks
5	PostgreSQL 16 + pgvector	Software	JDBC; schema managed by Flyway	All business data and face embeddings	Implemented
6	Apache Kafka	Software	Kafka topics	Detection and incident events between AI Service and backend	Implemented
7	Google Identity Service	External system	Google ID token, verified with Google public keys	"Log in with Google"	Implemented
8	E-mail service (Gmail SMTP)	External system	SMTP	Account setup and password reset e-mails	Implemented
9	Google Drive	External system	Google Drive API (OAuth, scope drive.file)	Archive of recorded video segments	Planned — not implemented

4.2 Quality Attributes

The three measurable targets below come from the registration form. Each row states how it will be measured and the current evidence; a target without a measurement will be lowered or removed before Report 5.

4.2.1 Usability

ID	Requirement	Evidence
NFR-U1	All user-facing text of the web client and the mobile app is in Vietnamese; this document quotes it in English.	Implemented
NFR-U2	Every rejected action shows a message that names the reason (and the limit or state when relevant); messages are listed in 5.3.	Implemented for the access-control part
NFR-U3	Lists are paginated (20 rows per page by default) and keep filters in the address so a notification can open the referenced row.	Implemented for the access-control part

4.2.2 Reliability

ID	Requirement	How it is measured	Current evidence
NFR-R1	Availability of at least 99.5% during monitoring hours.	Uptime of the backend and AI Service over a test week (health endpoint polled every minute).	Not measured yet
NFR-R2	Surveillance events are kept during a temporary network interruption between AI Service and backend.	Disconnect the backend for N minutes during detection, then count the events received after reconnection.	Not measured yet

ID	Requirement	How it is measured	Current evidence
NFR-R3	Concurrent business updates do not lose data: two users acting on the same record get one success and one conflict message.	Integration tests with parallel calls (conditional updates and optimistic locking).	Implemented and covered by automated tests (access requests, assignments, areas, schedules)
NFR-R4	Scheduled jobs process each record once: a batch is rolled back when the number of updated rows differs from the number locked.	Integration tests of the expiry and finish jobs.	Implemented and tested

4.2.3 Performance

ID	Requirement	How it is measured	Current evidence
NFR-P1	An alert reaches the Security Officer within 3 seconds after a person enters a restricted area.	End-to-end: time from the frame in which the person appears to the alert on the monitoring screen; at least 30 runs; report median.	Only the AI pipeline processing time has been benchmarked (PR #130); the end-to-end time is not measured yet

4.2.4 Security

ID	Requirement	Evidence
NFR-S1	Role-based access control on every endpoint (Administrator, Facility Manager, Security Officer, Authorized User) plus service-level scope filters.	Implemented; matrix in 3.1.3
NFR-S2	Stateless JWT authentication; passwords hashed with BCrypt; Google sign-in through verified Google ID tokens.	Implemented
NFR-S3	Service-to-service calls from the AI Service use a shared key in the X-Service-Key header; user tokens are not accepted there.	Implemented (BR-CE-11)
NFR-S4	Encrypted transport (TLS) for web, mobile and service traffic.	Not implemented — deployment requirement
NFR-S5	Stored images are encrypted at rest and never exposed by direct link.	Implemented: MinIO SSE-S3; images served by the backend after a permission check (section 14 of 5.1)

5. Requirement Appendix

5.1 Business Rules

1. Access Request

ID	Rule Definition
BR-RQ-07	If the caller is not an Authorized User, then creating an individual, group or generic access request is forbidden (403). Only Authorized Users create access requests.
BR-RQ-20	If the target area is Public, then an access request cannot be created.
BR-RQ-21	If the area does not exist or is soft-deleted, then the request is rejected with "area does not exist or has been deactivated".
BR-RQ-22	If startTime is not strictly before endTime, then the request is rejected.
BR-RQ-23	If startTime is earlier than now minus the past-start buffer (ACCESS_REQUEST_PAST_START_BUFFER_MINUTES), then the request is rejected ("start time must not be in the past"). The web client does not check this itself with a fixed buffer; it shows the backend message.
BR-RQ-24	If startTime is later than now plus the maximum advance days, then the request is rejected; the message states the configured limit and the chosen number of days.
BR-RQ-25	If the duration exceeds the maximum duration (hours), then the request is rejected; the message states the configured limit and the entered hours (rounded up).
BR-RQ-26	If the area, start time, end time or purpose is missing, or the purpose exceeds 1000 characters, then the request is rejected by input validation.
BR-RQ-27	If an individual request is created, then the area's access level must be higher than the requester's level and at most ACCESS_REQUEST_MAX_LEVEL_GAP levels higher (default 1, allowed 1–2, read at run time); otherwise it is rejected (400) with "you already have enough level for this area" or

ID	Rule Definition
	"you can only request areas at most N levels above yours" (the message states both levels). A null level is treated as 1. With the default: level 1 → Confidential, level 2 → Highly Confidential, level 3 → no individual request.
BR-RQ-28	If the request is GROUP and the area is Highly Confidential and group-in-private (ACCESS_REQUEST_GROUP_ALLOWED_IN_PRIVATE) is not allowed, then the request is rejected (individual only). The requestable-area list returns a groupRequestAllowed flag per area computed by the same rule, and the web client offers the group type only when the flag is true.
BR-RQ-29	If a GROUP request has a null/empty member list, or only the requester's own code, then it is rejected; the requester's code and duplicate codes are silently removed (case-insensitive for the requester).
BR-RQ-30	If the number of distinct members (excluding the requester) exceeds the maximum group size, then the request is rejected; the message states the limit and the chosen count.
BR-RQ-MEM-01	If a member code does not exist, belongs to a deactivated or soft-deleted user, or the user is not an Authorized User, then the member is invalid; the same generic reason is returned for all cases.
BR-RQ-03	If a group request is created, then the requester must enter the area by access level (requester level ≥ area level); members below the area level are accepted and stored as sponsored = true when the area type is in ACCESS_REQUEST_SPONSOR_ALLOWED_AREA_TYPES (only Confidential); a group request in a Highly Confidential area is rejected unless ACCESS_REQUEST_GROUP_ALLOWED_IN_PRIVATE is on (off by default).
BR-RQ-31	If any participant (requester or member) already has a PENDING or APPROVED request for the same area whose time range overlaps, then the request is rejected (409) and the message lists "code - full name" of every conflicting participant. Different areas never conflict.
BR-RQ-32	If a request is created, then its status is PENDING; an individual request notifies all active Facility Managers (NEW_REQUEST_PENDING); a group request also notifies each member (ADDED_TO_GROUP). Notification failure does not roll back creation.
BR-RQ-33	If an Authorized User opens the area list of the request form (`available-areas?type=INDIVIDUAL
BR-RQ-34	If member codes are resolved, then: the list must be non-empty and not exceed the max group size; codes are normalised, de-duplicated preserving input order, looked up in one query; only code + full name are returned for valid users.
BR-RQ-35	If a user calls member lookup or member suggestions more times per minute than the configured limit, then the call is rejected with 429. The counter is shared by both endpoints and kept in memory per instance.
BR-RQ-36	If member suggestions are requested with an empty query, then up to 10 eligible users the caller added to their own previous group requests are returned (newest first); with a query, it must match ^[A-Za-z0-9-]{1,20}$ (else 400) and returns up to 10 eligible users whose code starts with the query (case-insensitive), ordered by code. The caller is always excluded; only code and full name are returned.
BR-RQ-37	If a user who is not a Facility Manager reads a request detail, then they must be the requester or a member; otherwise 403. The Facility Manager can read any request.
BR-RQ-38	If a review status is neither APPROVED nor REJECTED, then the review is rejected.
BR-RQ-39	If a request is REJECTED, then a rejection reason of 10–500 characters (trimmed) is mandatory; checked before any database access.
BR-RQ-06	If the reviewer is the requester of the request, then both approval and rejection are forbidden (403 ERR_AC_006) and the request stays PENDING.
BR-RQ-02	If a Facility Manager approves a PENDING request, then the rules are re-checked against current data: GROUP in Highly Confidential with group-in-private off → reject; any member now deactivated/deleted → reject; when the area type no longer allows sponsorship, any member below the area level → reject. The requester's access level is not re-checked.
BR-RQ-40	If two actors review/cancel the same request concurrently, then only the actor whose conditional UPDATE … WHERE status = 'PENDING' affects 1 row succeeds; the other gets 409 with who handled it, the resulting status and when. No status pre-check is performed.
BR-RQ-41	If a review or cancel succeeds (1 row updated), then — and only then — the audit record and notifications are produced (APPROVED/REJECTED to requester + members; CANCELLED to group members except requester). Notification failure never fails the business action.
BR-RQ-42	If someone other than the requester tries to cancel a request, then it is forbidden (403). Only PENDING requests can be cancelled (enforced by BR-RQ-40); a user cancel records cancel_source = USER and cancelled_by.

ID	Rule Definition
BR-RQ-43	If a PENDING request's start time has passed, then the scheduled job sets it to EXPIRED (locking exactly the rows to expire, auditing each, rolling back everything if counts mismatch) and notifies the requester (ACCESS_DENIED) only after commit. Review after the start time is blocked by BR-RQ-48.
BR-RQ-SP-05	If a requester is deactivated, deleted, or removed with their import batch, then every request they created that is PENDING or APPROVED and not yet ended is cancelled by the system (cancel source SYSTEM, reason "The requester is no longer active"), audited with actor System, and the members are notified (REQUEST_SYSTEM_CANCELLED) after commit. Reactivation does not restore the requests; deactivating a member does not change the request.
BR-RQ-45	If a user's own request list is queried, then it includes requests they created and group requests they are a member of, optionally filtered by status and area, newest first by default. Facility Manager sees all requests.
BR-RQ-46	If a request is marked FINISHED, then the actor must be a Facility Manager (the requester and the Administrator are forbidden, 403), the request must be APPROVED (400), the current time must be at or after its start time (400 ERR_AC_007), and a reason of 10–500 characters (trimmed) is mandatory; the reason is stored in the FINISH audit record, and the requester and all group members receive REQUEST_FINISHED with the Facility Manager's name and the reason. A notification failure does not fail the action. The status change is a conditional update … WHERE status = 'APPROVED' AND start_time <= now (AccessRequestRepository.finishIfApprovedStarted, merged PR #105): only the call that affects 1 row writes the FINISH audit and sends notifications; if 0 rows are affected (another Facility Manager finished it first, or the system cancelled it in between), the request is re-read and the call returns 409 without audit or notification. A second, non-overlapping attempt on an already FINISHED request still returns 400 (not APPROVED). Since V88 (merged PR #119) the same conditional update also stores the reason and the Facility Manager on the request (finish_reason, finished_by), and the request details show them; requests finished before V88 were back-filled from their latest FINISH audit record, and a FINISHED request without such a record keeps both fields empty. The action is offered on the "Access requests" tab of Request Approval. If the system job of BR-RQ-49 finishes the request first, the Facility Manager gets 409; only one FINISH audit exists.
BR-RQ-47	If a Facility Manager cancels an APPROVED request, then a reason of 10–500 characters is mandatory, and the cancellation succeeds only when the conditional update … WHERE status = 'APPROVED' AND start_time > now affects 1 row: the request becomes CANCELLED with cancel_source = STAFF, cancelled_by = the Facility Manager and the reason, a CANCEL audit is written, and the requester and all group members receive REQUEST_CANCELLED. If 0 rows are affected: a request that is still APPROVED has already started → 400 ERR_AC_008 (use Finish, BR-RQ-46); a PENDING request → 400 (use Reject); any other status → 409. Only the Facility Manager may call it; the requester's own cancel (BR-RQ-42) still covers PENDING requests only. Requests cancelled by a Facility Manager before migration V73 keep cancel_source = USER. The web client shows "Cancelled by manager: {reason}" on the request row and in the details popup (Access Requests and Request Approval (Access requests tab)).
BR-RQ-48	If a Facility Manager approves or rejects a PENDING request at or after its start time, then the action is rejected (409 ERR_AC_012) and the request stays PENDING until the expiry job sets it to EXPIRED (BR-RQ-43). The time check is part of the conditional update (… WHERE status = 'PENDING' AND start_time > now); when the update affects 0 rows, the request is re-read to report ERR_AC_012 or the BR-RQ-40 message. No audit, no notification.
BR-RQ-49	If an APPROVED request has reached its end time (end_time <= now), then a scheduled job (every 15 minutes, icss.scheduler.finish-elapsed-cron) sets it to FINISHED with the finish reason "Validity period ended" and no finisher, locking exactly the rows to finish, writing one ACCESS_REQUEST / FINISH audit per request with actor System, and rolling back everything if counts mismatch. No notification is sent. Screens show "Finished by the system: {reason}" when no finisher is recorded.

2. Entry Decision

ID	Rule Definition
BR-AC-20	If the user, the area or the time is missing, then the entry decision fails with an invalid-argument error.
BR-AC-21	If the user is soft-deleted or does not exist, then entry is denied (source NONE) as for an unknown user; if the user exists but is inactive (deactivated), then entry is denied (source NONE) with the reason "account deactivated". No assignment or other source can override this.

ID	Rule Definition
BR-AC-22	If the area does not exist, is inactive or soft-deleted, then entry is denied (source NONE).
BR-AC-23	If the user has a non-revoked assignment for the area with validFrom ≤ t < validTo (null validTo = unlimited), then entry is allowed with source ASSIGNED_PERSONNEL; this takes precedence over every other source.
BR-AC-24	If the user's access level is equal to or higher than the area's access level (Public 1, Confidential 2, Highly Confidential 3), then entry is allowed with source ACCESS_LEVEL. There is no explicit-authorization exception.
BR-AC-25	If the area is Confidential and one of its event sessions covers t (started_at ≤ t < actual end, or planned end while the session is open), then entry is allowed with source OPEN_EVENT. A time before the event opened is not admitted; a time inside a session that has since been stopped is still admitted. The area's current open flag is not used for this decision.
BR-ES-10	If the area is Confidential and a SCHEDULED event schedule covers t (startAt ≤ t < endAt), then entry is allowed with source OPEN_EVENT.
BR-GD-02	If the user is a Guard who has claimed a security incident of the area, and t is inside the incident-response window (BR-GD-03), then entry is allowed with source INCIDENT_RESPONSE and the incident ID as source reference, without an access request. The rule applies only to the Guard recorded as claimer and only to the incident's area; it is checked after the sources above, so it only opens areas the Guard cannot enter by access level: with the default Guard level 2, Highly Confidential areas. Guard shifts are not taken into account. Only the Guard's most recently claimed incident in that area is considered.
BR-GD-03	If an incident is still CLAIMED, then its incident-response window is [claim time, claim time + GUARD_INCIDENT_ACCESS_MINUTES); if it is RESOLVED_VERIFIED or RESOLVED_DISMISSED, then the window ends at the earlier of claim time + GUARD_INCIDENT_ACCESS_MINUTES and resolution time + GUARD_INCIDENT_EXIT_GRACE_MINUTES. A resolved incident without a resolution time grants nothing. Both values are read from System Configuration on every check, so a change applies from the next check.
BR-AC-26	If the user is the requester or a member of an APPROVED request for the area with startTime ≤ t < endTime, then entry is allowed with source ACCESS_REQUEST; PENDING, REJECTED, CANCELLED, EXPIRED and FINISHED requests never grant entry. Sponsored members are allowed only inside the window.
BR-AC-27	If none of the above sources applies, then entry is denied with source NONE.
BR-AC-28	If entry is denied and the user holds an APPROVED request for the area whose validity includes the calendar day of t (Asia/Ho_Chi_Minh), then the denial reason states that the request window has not started yet or has already ended that day (with the date and time); if no such request exists for that day, the generic denial reason is used.

2.1 Camera Entry Check

ID	Rule Definition
BR-CE-01	If a detection is reported by a camera, then its area is the area the camera is assigned to. Every camera belongs to exactly one active area: a camera cannot be assigned to an inactive area (BR-CAM-02) and an area that still has cameras cannot be deactivated (BR-AD-06). If, despite this, the camera's area is inactive or deleted, then the check is denied with the reason "area inactive" and logged with that area; an incident is never assigned to a guessed area.
BR-CE-02	If the detected person is a registered user, then entry is decided by BR-AC-20 … BR-AC-28 for that user, the camera's area and the detection time.
BR-CE-03	If the detected person is a guest whose biometric data is ready, then entry is decided by BR-GV-20.
BR-CE-05	If an entry check from a camera is completed (allowed or denied, area known), then it is recorded in the camera access log with camera, area, person, result, access source, reason and time; repeated checks of the same person at the same camera within ENTRY_LOG_DEBOUNCE_SECONDS are recorded once, and records older than ENTRY_LOG_RETENTION_DAYS are deleted by a daily job. The exit time is not recorded.
BR-CE-11	If a request to the camera entry-check endpoint or to an internal endpoint (/api/internal/**, e.g. the AI runtime configuration) does not carry the internal service key in the X-Service-Key header, then it is rejected with HTTP 401; user tokens are not accepted on these endpoints. If the key is not configured or shorter than 32 characters, then the backend does not start.

ID	Rule Definition
BR-CE-16	If the camera of a detection is DECOMMISSIONED, then the check is denied without evaluating the person and nothing is written to the camera access log.
BR-CE-12	If a camera entry check is denied and the detection time (Asia/Ho_Chi_Minh) lies within [AI_AFTER_HOUR_START, AI_AFTER_HOUR_END) — a window whose end is earlier than its start crosses midnight — then the access-log result is INTRUSION. Both values are read from System Configuration on every check (default 22:00 / 06:00), so a change applies from the next check.
BR-CE-17	If a camera entry check is denied, then the access-log result is chosen in this order: INTRUSION (BR-CE-12, or a denial reason mentioning after-hours / intrusion); ACCESS_OUT_OF_TIME (the reason mentions the request time window, "expired" or "not started"); UNKNOWN_PERSON (the person is not a registered user or guest, or was deleted); otherwise UNAUTHORIZED_ACCESS. An allowed check is AUTHORIZED_ACCESS. Known issue: the reason-based steps match keywords of the Vietnamese denial text (rule-based, not a reason code).

2.2 Access History

ID	Rule Definition
BR-AH-01	If a user reads "my access history", then only camera access records of that user are returned (allowed and denied); the user is taken from the login token and no request parameter can select another person; access levels are not returned. The Authorized User, the Facility Manager and the Administrator may call it; the Security Officer gets 403.
BR-AH-02	If a Facility Manager or an Administrator searches access history, then records of every person are returned, optionally filtered by area, camera code, person code (case-insensitive exact match), result and time range; the Authorized User and the Security Officer get 403 (the Security Officer reads access logs per camera).
BR-AH-03	If no time range is given, then the last 7 days are returned; if only the end is given, the 7 days before it; if only the start is given, from the start until now.
BR-AH-04	If the start of the range is after its end, then the request is rejected (400 ERR_AC_010).
BR-AH-05	If access history is listed, then records are sorted newest first, 20 per page by default and at most 100 per page.

3. Assigned Personnel

ID	Rule Definition
BR-AP-01	If the caller is not a Facility Manager, then creating or revoking an assignment is forbidden; the Facility Manager and the Administrator may list assignments.
BR-AP-05	If the area is inactive or soft-deleted, then no assignment can be created (ERR_AP_007). Listing history of an inactive area is still allowed.
BR-AP-20	If the area is Public, then assignment is not applicable (ERR_AP_010).
BR-AP-06	If the actor is the target user, then they cannot assign an assignment to themselves (403 ERR_AP_011); self-revocation is allowed.
BR-AP-04	If the target user does not exist (ERR_AP_005), is inactive or soft-deleted (ERR_AP_006), then the assignment is rejected. The user row is locked to serialise concurrent assignments.
BR-AP-02	If validTo is given, then it must be after validFrom (ERR_AP_002) and in the future (ERR_AP_003); validFrom defaults to now; null validTo means unlimited.
BR-AP-03	If the same user already has a non-revoked assignment in the same area whose half-open range [validFrom, validTo) overlaps (null = unlimited), then the assignment is rejected (409 ERR_AP_004); adjacent ranges do not overlap.
BR-AP-08	If an assignment is revoked, then a non-blank reason (10–500 chars) is mandatory, revocation is effective immediately (revokedAt = now), and a revoked record can no longer be revoked (409 ERR_AP_009).
BR-AP-28	If validFrom is given when creating an assignment, then it must not be earlier than now minus 5 minutes (clock tolerance), otherwise 400 ERR_AP_013; blank means now.
BR-AP-29	If an assignment is created, then it is one grant period and its validity cannot be edited afterwards (no update endpoint). Ending early means revoking it (BR-AP-08); granting again means creating a new assignment, which may start exactly at the previous validTo (BR-AP-03 half-open ranges). The Assigned Personnel popup offers "Next grant" on Active and Expired rows with a validTo, pre-filling the user and start = max(previous validTo, now).

ID	Rule Definition
BR-AP-30	If an assignment is revoked, then it must be ACTIVE or UPCOMING; an EXPIRED assignment is rejected (409 ERR_AP_012) with no change and no audit; an already revoked one keeps ERR_AP_009. The popup hides Revoke on Expired rows.
BR-AP-21	If the assignment status is displayed, then it is computed at read time: REVOKED if revoked; UPCOMING if now < validFrom; EXPIRED if now ≥ validTo; otherwise ACTIVE. It is not stored.
BR-AP-22	If the record id does not belong to the area in the path, then the operation returns 404 (ERR_AP_001).
BR-AP-23	If an assignment is created, then userId is mandatory, note ≤ 1000 chars (blank stored as null), and reason 10–500 chars.
BR-AP-24	If a user account is deactivated, then every ACTIVE and UPCOMING assignment of that user (not revoked, validTo null or later than now) is revoked in the same transaction: revokedAt = now, revokedBy = the Administrator performing the action, reason "User account deactivated"; each revocation is audited (AREA_ASSIGNMENT / REVOKE) and all audit records of the action, including the request cancellations of BR-RQ-SP-05, share one correlation id. Reactivating the account does not restore any assignment.
BR-AP-25	If a user account is soft-deleted, individually or with its import batch, then the same revocation applies with reason "User account deleted"; restoring the account or the batch does not restore any assignment. Assignments of accounts that were already deactivated or deleted before this rule are revoked once by migration V86 (audit actor System, source FLYWAY_MIGRATION_V86).
BR-AP-26	If assignments are revoked because of an account deactivation or deletion, then no notification is sent to the affected user (the account can no longer sign in). Area deactivation (BR-AD-04) still notifies the assignees.
BR-AP-27	If an account is deactivated or deleted, then the user row is locked first (a batch locks its users in id order), so an assignment created concurrently is either committed before and then revoked, or rejected afterwards by BR-AP-04.

4. Access Level and Area Type Defaults

ID	Rule Definition
BR-AL-03	If an access-control change is submitted (user access level, assignment create/update/revoke), then a reason of 10–500 characters is mandatory; otherwise 400 and nothing is changed or logged.
BR-AL-06	If an access-control change does not alter any value (new == old), then nothing is saved and no audit record is written; the current state is returned.
BR-AL-01	If an access-control change is saved, then an audit record (old → new snapshot, reason, actor) is written in the same transaction.
BR-AL-02	If anyone tries to update or delete a row of the audit log, then a database trigger rejects it (append-only).
BR-AL-08	If the caller is not Administrator or Facility Manager, then reading audit logs is forbidden.
BR-AL-20	If the caller is not a Facility Manager, then changing a user's access level is forbidden; the new level must be 1–3.
BR-AL-21	If the actor tries to change their own access level, then it is forbidden (403).
BR-AL-22	If the target user does not exist or is soft-deleted, then the access-level change returns 404.
BR-AL-23	If users are searched for access-level management, then the keyword is optional (empty or missing returns all active users, so the list loads page 1 when the screen opens and again when the keyword is cleared), an optional current access level filter may be given, page size is between 1 and 20, only active users are returned, and only id, code, name, role and access level are exposed.
BR-AL-24	If an account is created, then its access level defaults to the configured value for its role. If the role has no configuration key, or the role is empty, the default is 1. If the default-level configuration row of a role is missing from System Configuration, the system falls back to the seeded default (Authorized User 1, Guard 2, Facility Manager 3, Administrator 3). Changing a default never changes existing accounts.
BR-AL-28	If a Facility Manager changes the access level of several users at once, then the list must not be empty, its distinct size must not exceed USER_BULK_IMPORT_MAX_ROWS (400, the message states the limit and the chosen count), the level must be 1–3 and a reason of 10–500 characters is mandatory; each user is then processed separately with the single-user rules (BR-AL-06, BR-AL-20..22) in its own transaction, so one failure does not affect the others; each user's result is

ID	Rule Definition
	UPDATED, UNCHANGED or FAILED (with the error message), and each change is audited separately, sharing the request's correlation id. Only the Facility Manager may call it.
BR-AL-29	If the target account of an access-level change is deactivated, then the change is rejected with 409 ERR_AC_009 (the message names the user code), even when the new level equals the current one; nothing is saved or audited. In a bulk change (BR-AL-28), that user's result is FAILED with this message and the other users are processed.
BR-AL-30	If a user is the requester or a member of at least one PENDING access request, then changing that user's access level (raise or lower, single or bulk) is rejected with 409 ERR_AC_011 naming the pending requests, and nothing is saved or audited; in a bulk change that user is FAILED and the others continue. APPROVED requests do not block; setting the current level again stays a no-op (200). Level changes and request creation lock the affected users rows (group requests in id order), so a request created first makes a later level change fail, and a level change committed first is used by a later request.
BR-PR-23	If an area is created or its type changes, then its access level is set to the level of the type (Public 1, Confidential 2, Highly Confidential 3); the level cannot be changed independently: PATCH …/access-rules returns 400 ERR_AREA_056 and preset updates return 400 ERR_AC_005, even when the value equals the type's level.

5.1 Area — Create, Edit, Name and Coordinates

ID	Rule Definition
BR-AR-20	If the caller is not an Administrator, then creating, editing, deactivating, restoring, previewing type change / dependencies, assigning cameras of an area are forbidden; the Administrator and the Facility Manager can list and read areas; the Administrator, the Facility Manager and the Guard can read map pins and area cameras.
BR-AR-01	If an area name is submitted, then it is normalised to Unicode NFC, trimmed and consecutive spaces collapsed to one before any check or save.
BR-AR-02	If the normalised name is null or not 3–100 characters, then it is rejected (ERR_AREA_005).
BR-AR-03	If the name contains no letter (Unicode, incl. Vietnamese), then it is rejected (ERR_AREA_018).
BR-AR-04	If the name contains characters other than letters, digits, normal space and - _ ( ) . , /, then it is rejected (ERR_AREA_019).
BR-AR-05	If another non-deleted area on the same floor already has the same name (case-insensitive), then create / update / restore is rejected (409 ERR_AREA_020); a database unique index is the final guard. The same name on another floor, or the same name as a soft-deleted area, is allowed.
BR-AR-21	If the floor cannot be resolved (by floorId, or by building + floor name), then create/update is rejected (ERR_AREA_021); building and floor names stored on the area are copied from the floor record.
BR-AR-22	If the area type (areaLevel) is missing, then create/update is rejected (ERR_AREA_003).
BR-AR-COORD-01	If both centre coordinates are empty, then the area is stored as "not located" (null) and is not shown on the map.
BR-AR-COORD-02	If only one of the two centre coordinates is provided, then create/update is rejected (ERR_AREA_006, "Enter both latitude and longitude, or leave both empty."); the web client shows the error under the empty field.
BR-AR-COORD-03	If both coordinates are cleared on update, then the stored coordinates become null.
BR-AR-23	If a coordinate is outside latitude −90..90 or longitude −180..180, then the request is rejected by both the web form and the backend input validation (@DecimalMin / @DecimalMax in backend/src/main/java/com/fa26se040/icss/dto/area/AreaCreateRequest.java:34-39 and AreaUpdateRequest.java:34-39).

5.2 Area — Version Check and Reason

ID	Rule Definition
BR-TC-13	If an area write (update, event mode, deactivate, restore) is sent without version, then it is rejected (400 ERR_AREA_044); if the version differs from the locked row, it is rejected (409 ERR_AREA_045). Event schedule create / update / cancel do not require a version.
BR-TC-17	If a write really changes the area row, then version = version at start + 1 (only once per operation); a save that changes nothing keeps the version.

ID	Rule Definition
BR-TC-02	If the area type changes, then a reason of 10–500 characters (trimmed) is mandatory (400 ERR_AREA_050); for other edits the reason is optional but, if given, must also be 10–500.
BR-TC-12	If only non-type fields change (e.g. rename), then no reason is required, no CHANGE_TYPE audit and no AREA_TYPE_CHANGED notification are produced; an UPDATE audit is written only when something changed.

5.3 Area — Type Change

ID	Rule Definition
BR-TC-01	If the caller is not Administrator, then changing the area type is forbidden (403), nothing changes and nothing is notified.
BR-TC-03	If the Administrator previews a type change, then the same evaluation as the real change is returned: new access level, number of active assignments, APPROVED requests to cancel, PENDING requests to cancel (to Public) or not approvable, event mode / schedule state and blocking reasons. Read-only; the real change evaluates again after locking the area.
BR-TC-04	If the type changes, then the access level becomes the level of the new type (BR-PR-23).
BR-TC-05	If event mode is active and the new type does not allow event mode (Public / Highly Confidential), then the type change is blocked (409 ERR_AREA_048).
BR-TC-06	If SCHEDULED event schedules exist and the new type does not allow event mode, then the change is blocked (409 ERR_AREA_042) and the message lists up to 5 schedules.
BR-TC-07	If the new type is Public and the area still has non-revoked, non-expired assigned personnel, then the change is blocked (409 ERR_AREA_049, with the count).
BR-TC-08	If an APPROVED, not-yet-ended request no longer satisfies the new type, then it is cancelled by the system in the same transaction (source AREA_TYPE_CHANGE) with a reason describing the violation: an individual request whose requester is now more than ACCESS_REQUEST_MAX_LEVEL_GAP levels below the new level (a requester who now enters by level keeps the request); a group request whose requester cannot enter the new type by level; a group request in Highly Confidential while group requests are not allowed there; members failing the sponsorship rule. PENDING requests are kept and only counted when the review (BR-RQ-02) would block them.
BR-RQ-03/04 (type change)	If a sponsored member is below the new level but the new type allows sponsorship, then the request is kept; if the new type disallows sponsorship, the member is checked like a normal member (cancel only when below level).
BR-TC-09	If a PENDING request no longer satisfies the new type, then it is not cancelled — it is only counted as "not approvable" (the Facility Manager's approval will be blocked by BR-RQ-02).
BR-TC-14	If the new type is Public, then every PENDING and APPROVED not-yet-ended request of the area is cancelled by the system with the fixed reason "The area is now public; no request is needed".
BR-TC-15	If a request is cancelled, then cancel_source (USER = the requester cancelled a PENDING request; STAFF = a Facility Manager cancelled an APPROVED request; SYSTEM), cancelled_by (null for SYSTEM) and cancel_reason are stored.
BR-TC-10	If a type change succeeds, then after commit every active Facility Manager receives AREA_TYPE_CHANGED (old → new type, reason, number of cancelled requests); inactive Facility Managers and other roles do not.
BR-TC-16	If a request is cancelled by the system, then exactly one REQUEST_SYSTEM_CANCELLED notification per request is sent after commit to the requester and members (deduplicated).
BR-TC-11	If the type change is blocked or fails midway, then nothing changes (type, level, requests), no audit is written, no notification is sent and the version is unchanged (single transaction).
BR-TC-18	If a type change succeeds, then one CHANGE_TYPE audit plus one CANCEL audit per system-cancelled request (actor System AREA_TYPE_CHANGE) are written with a shared correlation id.

5.4 Area — Deactivation and Restore

ID	Rule Definition
BR-AD-01	If the Administrator deactivates an area, then a reason (10–500) and version are mandatory; an already deactivated area returns 409 ERR_AREA_053; the old DELETE endpoint no longer exists. Only the Administrator may deactivate.
BR-AD-06	If cameras (not deleted) are still assigned to the area, then deactivation is blocked (409 ERR_AREA_009) listing camera code – name.

ID	Rule Definition
BR-AD-02	If the area has security incidents in status NEW or CLAIMED, then deactivation is blocked (409 ERR_AREA_051, with the count); resolved incidents do not block.
BR-AD-03	If event mode is active (open and not past openUntil), then deactivation is blocked (409 ERR_AREA_052); an event already past openUntil does not block.
BR-AD-03b	If SCHEDULED event schedules exist, then deactivation is blocked (409 ERR_AREA_042, listing schedules).
BR-AD-04	If deactivation proceeds, then all ACTIVE and UPCOMING assignments are revoked (revoked by the Administrator, reason "Area deactivated: <reason>" truncated to 500 characters), each revocation is audited, and each assignee receives ACCESS_PERMISSION_REVOKED after commit.
BR-AD-05	If deactivation proceeds, then all PENDING and APPROVED not-yet-ended requests are cancelled by the system (actor System AREA_DEACTIVATION) and requester + members receive REQUEST_SYSTEM_CANCELLED after commit.
BR-AD-09	If deactivation proceeds, then PENDING guest visits of the area are cancelled and APPROVED not-ended guest visits are revoked, via the guest-visit flow.
BR-AD-20	If any blocker exists, then nothing is revoked or cancelled; if any step fails, the whole deactivation rolls back. The area gets is_active = false, deleted_at = now, version + 1 and a DEACTIVATE audit.
BR-AD-08	If the Administrator opens the dependency preview, then the same evaluation as the real deactivation is returned read-only (blockers and the numbers of assignments, requests and guest visits to be handled).
BR-AD-21	If an area is deactivated, then later writes to it (event mode, schedules, edit, camera assignment, assignment, new requests, new guest visits) are rejected.
BR-AD-07	If the Administrator restores an area, then a reason (10–500 characters) and version are mandatory; the area must currently be deactivated (409 ERR_AREA_054), its floor and building must be active (409 ERR_AREA_055), and no active area on the same floor may have the same name (409 ERR_AREA_020). Assignments, requests, guest visits and cameras are not restored automatically.

5.5 Area — Camera Assignment and Access Rules

ID	Rule Definition
BR-CAM-02	If cameras are assigned to an inactive or deleted area, then it is rejected (ERR_AREA_017); if any camera id does not exist, it is rejected (ERR_CAM_002).
BR-CAM-03	If any camera to assign is not in status ACTIVE, then the assignment is rejected (ERR_MAP_002).
BR-CAM-04	If a camera list is saved, then cameras no longer in the list are unassigned, listed cameras are (re)assigned to this area even if they belonged to another area, an empty list clears all; one UPDATE_CAMERAS audit is written.

5.6 Area — Event Mode

ID	Rule Definition
BR-EV-20	If the caller is not a Facility Manager, then disabling event mode (Stop) and creating / updating / cancelling schedules are forbidden; the Facility Manager and the Administrator may list schedules.
BR-EV-A1	If the request contains the legacy field enabled, then it is rejected (ERR_AREA_046); action is mandatory (ERR_AREA_047) and only DISABLE is accepted (BR-EV-A7).
BR-EV-A4	If any input is invalid, then the request is rejected (400) before the area is locked: a reason code is mandatory (ERR_AREA_024); the note is optional for DISABLE (blank is stored as empty) but an entered note must be 10–500 characters; version is mandatory (ERR_AREA_044).
BR-EV-A2	If the reason code is not in the EVENT_DISABLE catalog group, then it is rejected: exists in another group → ERR_AREA_026; not found or inactive → ERR_AREA_025. The EVENT_ENABLE and EVENT_EXTEND groups are hidden from the Reason Catalog filter and add form; their data is kept.
BR-EV-A7	If PATCH /event-mode carries an action other than DISABLE, then it is rejected (400 ERR_AREA_058). Event mode is opened only by the schedule activation job and closed only at the planned end (BR-EV-28) or by a Facility Manager's Stop (DISABLE).
BR-EV-A3	If, after locking, DISABLE is sent while event mode is inactive or expired, then it is rejected (409 ERR_AREA_030) with a message describing the real state.
BR-EV-A5	If ERR_AREA_030 is raised, then the message states one of: "open until {t}", "disabled at {t}", "expired at {t}", or "off".
BR-EV-22	If the area type is not Confidential, then event mode is not allowed (ERR_AREA_022).

ID	Rule Definition
BR-EV-25	If scheduling would make the total open hours (sessions + SCHEDULED schedules + the candidate) in the rolling window ending at the candidate's end, or at the end of any later schedule, exceed the budget, then it is rejected (ERR_AREA_028) with used/remaining/requested hours.
BR-EV-26	If DISABLE is accepted, then the current session is closed and, if it came from a schedule, that schedule is set to ENDED_EARLY.
BR-EV-A6	If a schedule is activated after the previous session's openUntil has passed but before the job closed that session, then the expired session is closed first and a new session with a new start time is opened; guards are notified.
BR-EV-27	If event mode changes (activation by schedule, disable), then one AREA_EVENT_MODE audit (reason code, label, note) is written and every active Guard receives EVENT_MODE_CHANGED.
BR-EV-28	If an active session reaches its planned end, then it is closed (actualEnd = plannedEnd, actor System, EXPIRE_EVENT_MODE audit), its source schedule becomes COMPLETED and the area flag is cleared; this runs every minute and on every event-mode write. After the closing transaction commits, every active Guard receives EVENT_MODE_CHANGED once per closed session ("Area {name}: event mode ended automatically at {plannedEnd}").
BR-EV-29	If an active session will end within the reminder lead time, then its starter (if still an active Facility Manager) — otherwise all active Facility Managers — receives EVENT_MODE_EXPIRING once. Lead time 0 disables reminders.
BR-EV-30	If a configured event-mode limit is outside its allowed range at read time, then the code falls back to a built-in default instead of the stored value.

5.7 Area — Event Schedule

ID	Rule Definition
BR-ES-20	If a schedule is created or updated, then: area active (ERR_AREA_017); type Confidential (ERR_AREA_022); startAt in the future (ERR_AREA_032); startAt ≤ now + max lead days (ERR_AREA_033); endAt after startAt (ERR_AREA_034); duration ≥ min minutes (ERR_AREA_035) and ≤ max hours (ERR_AREA_036); an event title of 1–150 characters after trimming is mandatory (ERR_AREA_057, V87); a reason code is mandatory (ERR_AREA_024); the note is optional when creating (blank is stored as empty, PR #118) and mandatory when updating, and an entered note must be 10–500 characters (ERR_AREA_024).
BR-ES-L2	If the schedule reason code is not in its group (create → EVENT_SCHEDULE_CREATE, update → EVENT_SCHEDULE_UPDATE, cancel → EVENT_SCHEDULE_CANCEL), then it is rejected (ERR_AREA_026 / ERR_AREA_025).
BR-ES-21	If a schedule overlaps another SCHEDULED schedule of the area, then it is rejected (409 ERR_AREA_037); adjacent schedules are allowed.
BR-ES-22	If a schedule overlaps the currently active session, then it is rejected (409 ERR_AREA_038).
BR-ES-23	If the area already has the maximum number of SCHEDULED schedules, then a new one is rejected (ERR_AREA_039).
BR-ES-24	If a schedule is created/updated, then the event budget (BR-EV-25) is checked, excluding the schedule itself on update.
BR-ES-25	If a schedule is updated or cancelled, then it must belong to the area (ERR_AREA_043) and be SCHEDULED (409 ERR_AREA_040); an update keeps the original reason code/label/note on the schedule, while the reason code and note entered for the edit are recorded only in the UPDATE audit record (the edit form starts with an empty note); a cancel stores cancel reason, by, at.
BR-ES-26	If a schedule is created, updated or cancelled, then one AREA_EVENT_SCHEDULE audit is written and active Guards are notified (EVENT_MODE_SCHEDULED); the notification names the Facility Manager who performed the action (creator, editor or canceller).
BR-ES-17	If a SCHEDULED schedule's start time is reached, then the job (every minute, one transaction per schedule) activates it: closes expired sessions, opens a session from startAt to endAt, sets STARTED, audits ENABLE_EVENT_MODE as System and notifies guards after commit.
BR-ES-31	If the job activates or reminds a schedule, then it locks the area before reading the schedule and acts only if the schedule is still SCHEDULED; a schedule cancelled or updated while the job waits is never activated and its cancellation data is kept.
BR-ES-27	If at activation the schedule's end time has passed, the area is inactive, or its type no longer allows event mode, then the schedule becomes FAILED with a reason, a FAIL audit is written and EVENT_MODE_SCHEDULE_FAILED is sent to the creator if still an active Facility Manager, otherwise to all active Facility Managers; no session is created.

ID	Rule Definition
BR-ES-28	If a SCHEDULED schedule starts within the reminder lead time and was not yet reminded, then it is reminded once (EVENT_MODE_SCHEDULE_STARTING) to the creator if still an active Facility Manager, otherwise to all active Facility Managers; lead time 0 disables reminders.
BR-ES-S1	If a session created from a schedule closes, then the schedule becomes COMPLETED (expired) or ENDED_EARLY (Facility Manager disabled) in the same transaction; the audit snapshot records the schedule id and new status (BR-ES-S2).
BR-ES-07	If the Administrator lowers event-mode limits, then active events and SCHEDULED schedules violating the new limits are not cancelled; Facility Managers are notified (EVENT_MODE_LIMIT_CHANGED) listing them.
BR-ES-L1	If schedule statuses are shown, then the web client label follows the stored status (it is not recomputed from the viewing time).
BR-ES-29	If the Facility Manager or the Administrator opens Event Management (GET /api/event-schedules, PR #118), then schedules of every area are listed, latest start first, 20 per page by default and at most 100; optional filters: stored status (several allowed; an unknown value is rejected, 400), area, a date range that keeps schedules overlapping [from 00:00, to + 1 day 00:00) in Vietnam time (from after to is rejected, 400), and a keyword matched case-insensitively against the event title or the area name. Other roles are forbidden (403).
BR-ES-30	If the user on Event Management is a Facility Manager, then the screen offers Create (only active Confidential areas are offered), Edit and Cancel on a SCHEDULED schedule, and Stop on a STARTED one (Stop sends event-mode DISABLE, BR-EV-26); the Administrator sees the list and the details only. The change history of a schedule is read in the Audit Log, which shows the event title (V87 adds title to the AREA_EVENT_SCHEDULE audit snapshot; records written before V87 have no title). (web client, no test)

6. Guest Visit

ID	Rule Definition
BR-GV-20a	If the caller is not an Authorized User or Facility Manager, then creating, viewing own, cancelling guest visits, reading the host eligibility and the selectable areas are forbidden (the Administrator does not host guests); viewing one visit and listing all visits are for the Facility Manager and the Administrator (one visit also for its host); review and revoke are for the Facility Manager only; attaching a photo and getting a photo link are for the Administrator only.
BR-GV-01	If the host is not active, is soft-deleted, has a role other than Authorized User / Facility Manager (the Administrator is not a host), or has an access level below the minimum host level (GUEST_HOST_MIN_LEVEL), then they cannot invite guests (403 ERR_GUEST_002, the message states the minimum level). The web client reads the caller's eligibility (GET /api/guest-visits/eligibility: can host, own level, minimum level) and, when the caller cannot host, hides "Create guest visit" and shows the required level; the backend check still applies.
BR-GV-02	If the guest list is empty or exceeds the maximum per visit (ERR_GUEST_003), a guest name is not 2–100 characters after trim (ERR_GUEST_004), or an organisation exceeds 200 characters (ERR_GUEST_005), then the visit is rejected. The request body must not contain any field outside the model (ID number, phone, address, e-mail…) — unknown fields → 400.
BR-GV-03	If the visit purpose is not 10–500 characters after trim, then the visit is rejected (ERR_GUEST_006).
BR-GV-05	If startTime or endTime is missing (ERR_GUEST_020), start is not in the future (ERR_GUEST_010), start is not before end (ERR_GUEST_011), duration exceeds the max hours (ERR_GUEST_012), or start is beyond the max advance days (ERR_GUEST_013), then the visit is rejected.
BR-GV-04	If no area is selected, an id is empty or duplicated (ERR_GUEST_007), an area does not exist or is inactive (ERR_GUEST_008), or an area is not Confidential (ERR_GUEST_009), then the visit is rejected. The web form loads its areas from GET /api/guest-visits/selectable-areas (active Confidential areas; since V83 there are only three area types).
BR-GV-06	If, for any selected area, the host cannot enter during the whole [start, end) window via ACCESS_LEVEL (host level ≥ area level) or via a non-revoked assignment covering the whole window, then the visit is rejected (403 ERR_GUEST_014, names the area). Approved access requests and event mode do not count.
BR-GV-33	If a guest visit is created, then it is PENDING, a CREATE audit is written and all active Facility Managers receive GUEST_VISIT_PENDING after commit.
BR-GV-07	If the same guest (same full name and organisation) appears in two APPROVED visits whose times overlap, then the Facility Manager is warned, without blocking. [NOT IMPLEMENTED]

ID	Rule Definition
BR-GV-09	If the host cancels a visit, then version is required (ERR_GUEST_015), the caller must be the host (else 404), the version must match (409 ERR_GUEST_016), the status must be PENDING or APPROVED (409 ERR_GUEST_017), the visit must not have ended (409 ERR_GUEST_018); reason is optional but if given must be 10–500 (ERR_GUEST_019). Cancelling an APPROVED visit deletes guest biometrics immediately.
BR-GV-10	If a Facility Manager reviews a visit, then version is required, decision must be APPROVED or REJECTED (ERR_GUEST_024), rejection requires a 10–500 reason, the Facility Manager must not be the host (403 ERR_GUEST_022), and the status must be PENDING (409 ERR_GUEST_017). In the visit details popup, approve, reject and revoke are shown only to a Facility Manager who is not the host; a Facility Manager viewing a visit they host sees a note instead, and the Administrator only views.
BR-GV-12	If the visit's start time has been reached, then it can no longer be approved (409 ERR_GUEST_023); the job sets PENDING visits with now ≥ start to EXPIRED and notifies the host.
BR-GV-11	If a Facility Manager approves, then BR-GV-01, 04, 05 (except "start in the future") and 06 are re-checked against current data; the first violation is returned (409 ERR_GUEST_021).
BR-GV-34	If a visit is approved, then the host receives GUEST_VISIT_APPROVED and every active Administrator receives GUEST_PHOTO_REQUIRED; if rejected, the host receives GUEST_VISIT_REJECTED with the reason. All after commit.
BR-GV-13	If a Facility Manager revokes a visit, then version and a 10–500 reason are required, the Facility Manager must not be the host (403 ERR_GUEST_022), status must be APPROVED (409 ERR_GUEST_017) and not ended (409 ERR_GUEST_018); the visit becomes REVOKED, biometrics are deleted immediately and the host is notified.
BR-GV-32	If two actors change the same visit concurrently, then the row is locked and the version compared; exactly one succeeds and the other gets 409 ERR_GUEST_016 / ERR_GUEST_017; each successful change increments the version.
BR-GV-14	If the Administrator attaches a guest photo, then the visit must be APPROVED and not ended and the guest's biometrics not DELETED (409 ERR_GUEST_030); the guest must belong to the visit (404 ERR_GUEST_032); the visit row is locked.
BR-GV-15	If consent is not confirmed or the consent notice version sent differs from the current one, then the photo is rejected (400 ERR_GUEST_031, states the current version); the confirming Administrator, time and version are stored.
BR-GV-35	If the photo is not JPG/PNG or exceeds the size limit, then it is rejected (ERR_GUEST_033, states the KB limit).
BR-GV-17	If the AI Service fails or returns no valid 512-dimension embedding, then the photo is rejected (503 ERR_GUEST_035); if the photo does not contain exactly one face, it is rejected (400 ERR_GUEST_034, states the detected count). The embedding is stored in a separate table, not in face_data.
BR-GV-16	If a photo is attached again, then the old photo object and embedding are deleted (audit DELETE_BIOMETRIC) — the old object is deleted only after commit (rollback keeps it).
BR-GV-36	If photo storage is unavailable (upload, retry of a pending deletion, or URL signing fails), then the operation fails with 503 ERR_GUEST_036.
BR-GV-18	If the Administrator requests a photo view URL, then the guest must have a photo (404 ERR_GUEST_037); a presigned URL valid for the configured TTL is returned and every issuance is audited (VIEW_PHOTO, URL not stored). The photo bucket stays private.
BR-GV-20	If a guest's entry is evaluated, then it is allowed only when: visit APPROVED; start ≤ t < end; area belongs to the visit; area active; area type accepts guests; host still eligible and covers the area for [t, end); biometric status PHOTO_READY (BR-GV-38). Otherwise the first failing reason is returned.
BR-GV-21	If the area is in event mode, then this does not grant entry to guests.
BR-GV-25	If an APPROVED visit's end time has passed, then the job sets it to COMPLETED (audited with actor System); biometrics are kept until end + face retention hours.
BR-GV-27	If end + face retention hours (current config) or the embedding's expires_at is reached — or the visit is CANCELLED/REVOKED/EXPIRED/REJECTED — then the photo and embedding are deleted; if storage fails, the embedding is still deleted, the guest becomes DELETED and the photo is marked for retry.
BR-GV-29	If the visit end time plus the record retention days has passed, then the guest's name becomes "Anonymised guest" and the organisation is cleared (audit ANONYMIZE).

ID	Rule Definition
BR-GV-30	If a guest/visit state changes (create, approve, reject, cancel, revoke, expire, complete, attach/delete/view photo, anonymise), then an audit event is written; only the Administrator can read GUEST-module audit.
BR-GV-37	If an area is deactivated, then PENDING guest visits containing it are CANCELLED (host gets GUEST_VISIT_CANCELLED_BY_SYSTEM) and APPROVED ones are REVOKED through the Facility Manager revoke flow; visits already ended or changed concurrently are skipped.
BR-GV-38	If a guest's entry is evaluated and the guest's biometric status is DELETED, then entry is denied with BIOMETRIC_DELETED; if it is any other status than PHOTO_READY (no photo, photo without a valid embedding, or empty), entry is denied with BIOMETRIC_NOT_READY. Only a guest whose photo and 512-dimension embedding are registered can be recognised. The enum value PHOTO_ONLY (photo without embedding) exists but no code path assigns it; a photo whose embedding cannot be built is rejected at upload. The web client marks an APPROVED visit that still has guests without PHOTO_READY with "No photo yet (x/y guests)" on My Guest Visits, Request Approval (Guest visits tab) and Guest Photos; the host also sees "Guests must register their face at the desk before the visit".
BR-GV-39	If an APPROVED visit that has not started still has guests whose biometric status is not PHOTO_READY and the current time is within [start − GUEST_PHOTO_REMINDER_MINUTES_BEFORE, start), then the guest visit job (every minute) sends GUEST_PHOTO_REQUIRED once to every active Administrator; no reminder is sent if a GUEST_PHOTO_REQUIRED for the visit already exists created at or after the window start (including the one sent on approval). The message names the host, areas, time window, purpose and the number of guests without a photo, but not the guests' names.
BR-GV-40	If a user who is not a Facility Manager or Administrator views a visit they do not host, then 404 is returned (existence is not revealed); a Guard gets 403; hosts list only their own visits; the Facility Manager and the Administrator can view any visit. (Moved from BR-GV-07 on 2026-10-10.)
BR-GV-41	If the selectable-areas list of the guest visit form is requested with both a start and an end time, then each area also carries hostCanInvite and reasonCode, computed with the same rules as creating the visit: the caller not eligible as a host → false, ERR_GUEST_002; the caller cannot enter the area for the whole window by access level or by an assignment covering the window (BR-GV-06) → false, ERR_GUEST_014; an end time not after the start → 400 ERR_GUEST_011. Without both times the two fields are omitted. The web form greys out an area that cannot be invited to, prevents ticking it, shows the reason, unticks it if it was ticked, and recomputes when the time changes; creating the visit still applies BR-GV-06.

7. Account, Bulk Import and Authentication

ID	Rule Definition
BR-AU-20	If the caller is not an Administrator, then creating, importing, activating / deactivating and deleting accounts, managing import batches and looking up a user by code are forbidden; the Administrator and the Facility Manager may list users (the Facility Manager sees Guard accounts only).
BR-AU-21	If a Facility Manager lists users, then the result is limited to Guard accounts regardless of the requested account type, and totals of other account types are not revealed.
BR-AU-22	If a system account is created, then the role must be one of Facility Manager, Guard, Authorized User; an Administrator account cannot be created (single creation: 400; bulk import: the row fails) — Administrator accounts come only from the initial seed data; full name (3–100), code (1–50, letters, digits, _ and -), e-mail (valid, ≤ 255), role and a face photo are mandatory.
BR-AU-23	If the user code (case-insensitive, normalised) or e-mail (lower-case, normalised) already exists, then creation is rejected (409) listing which one is duplicated.
BR-AU-06	If an account is created (single or bulk), then a random 12-character temporary password is generated and stored hashed, and the account e-mail is sent only after the transaction has committed — for bulk import, after the row's own transaction has committed — so a rolled-back account never receives a mail. The mail is sent on a background executor (2–4 threads, queue of 500, thread prefix mail-): the request does not wait for the mail server, and a mail failure is logged at WARN without the password and does not affect the account. Every user value placed in the HTML mail (full name, user code, e-mail, temporary password) is HTML-escaped. The mail tells

ID	Rule Definition
	the user to set their own password with "Forgot password" on the Login screen; there is no change-password function.
BR-AU-07	If an account is created, then it is active by default and its access level is the role default (BR-AL-24).
BR-AU-04	If the face photo of a new account contains no face or more than one face, then registration is rejected; if the AI Service fails, the account is not created and the stored image is removed.
BR-AU-08	If a face photo is uploaded for an account, then it must be JPG/PNG and at most 350 KB.
BR-AU-24	If the Administrator tries to deactivate or delete their own account, then it is rejected. Together with BR-AU-20 (only the Administrator manages accounts) and BR-AU-22 (no new Administrator can be created), the seeded Administrator account cannot be locked out through the system.
BR-AU-25	If an account is toggled, then active ↔ inactive flips; only the deactivating direction cancels the user's active requests (BR-RQ-SP-05); deleting is a soft delete (deletedAt + inactive).
BR-AU-26	If a bulk import file is uploaded, then it must be a non-empty .zip containing metadata.xlsx or metadata.csv (plus images/<code>.jpg/.png); the metadata must have the required columns (Authorized Users: user_code, full_name, email; system accounts: also role) and at least one data row. If both files exist, metadata.xlsx is used.
BR-AU-27	If the number of data rows exceeds the configured maximum, then the whole file is rejected (message states the configured limit) — for both the Authorized User import and the system account import; a missing key falls back to 200.
BR-AU-28	If a row in the Authorized User import has a staff role (or an invalid role value), then that row fails; the system account import accepts staff roles except Administrator (an ADMIN row fails, BR-AU-22).
BR-AU-29	If a user code or e-mail appears more than once in the same file, then all those rows fail ("duplicated in import file").
BR-AU-30	If a row has an empty or > 50-char user code, an existing code, an empty or > 100-char full name, an empty, > 100-char, malformed or existing e-mail, a missing image images/<code>.jpg/.png, an image > 350 KB or not JPG/PNG, then that row fails with the reason; other rows continue (per-row result SUCCESS/FAILED).
BR-AU-31	If a bulk import runs, then all created users share one import batch id; a batch can be listed, inspected, soft-deleted (cancelling each user's active requests first) or restored (skipping users whose code/e-mail now conflict with an active account).
BR-AU-32	If a user logs in with e-mail / password or with Google, then the account must exist and be active; a wrong password, an inactive account, a soft-deleted account or an unknown e-mail all return the same 401 "Invalid email or password"; a token with the configured lifetime is issued.
BR-AU-33	If a password reset is requested, then the response is always HTTP 200 with the same message (MSG-AU-08), whether or not the e-mail belongs to an account; a single-use token is created and e-mailed only when the e-mail belongs to an active, not deleted account, and a mail failure is logged without changing the response. The token validity is read from PASSWORD_RESET_TOKEN_MINUTES when the token is created (default 15, allowed 5–60, V89; changing the value does not affect links already sent), the mail states the same number of minutes and is sent on the background executor of BR-AU-06, and neither the link nor the token is logged; resetting requires an unused, unexpired token whose account is still active. The new password has no length or strength rule.
BR-AU-34	If a request carries a valid, unexpired token, then the user is looked up in the database on every request; if the account does not exist, is deactivated or is soft-deleted, then the request is unauthenticated (401). The role used for authorization is the stored role, not the role in the token, so deactivation and role changes take effect immediately. The same check applies to real-time connections: a WebSocket (STOMP) CONNECT or SUBSCRIBE from a missing, deactivated or soft-deleted account is rejected, and the role and user id used for topic authorization come from the database. Subscriptions opened before the account was locked are closed by BR-AU-37.
BR-AU-35	If an account is created individually, then its face record is linked to the new user (face_data.user_id) in the same transaction; if any later step fails, the account and the face record are rolled back together. Bulk import saves the user before registering the face (BR-AU-31).
BR-AU-36	If a password reset link is built, then it uses the deployment setting APP_FRONTEND_BASE_URL (default http://localhost:5173); the origins allowed to call the API come from APP_CORS_ALLOWED_ORIGINS (comma-separated, default the three development origins).

ID	Rule Definition
	These are deployment settings, not business parameters, and are not editable in System Configuration.
BR-AU-37	If an account is deactivated, deleted, or removed by a bulk delete, then after the transaction has committed every open WebSocket session of that user is closed (close status POLICY_VIOLATION), which removes all its subscriptions; if the transaction rolls back, no session is closed. A client that reconnects is rejected at CONNECT (BR-AU-34). The backend keeps the open sessions per user for this purpose (WebSocketSessionRegistry, PR #119). No function changes the role of an existing account, so a role change while a session is open cannot occur.

8. System Configuration

ID	Rule Definition
BR-SC-20	If the caller is not an Administrator, then updating a configuration, reading its history and reloading the cache are forbidden; the Administrator and the Facility Manager can read the list.
BR-SC-21	If a value is updated, then it must be non-blank, the key must exist (404), the configuration must be editable, and a reason of 10–500 characters is required.
BR-SC-22	If the data type is INTEGER or DECIMAL, then the value must parse and lie within min/max (if set); BOOLEAN must be true/false; STRING ≤ 255 chars; AI_AFTER_HOUR_START/END must be HH:mm.
BR-SC-23	If EVENT_MODE_MIN_MINUTES > EVENT_MODE_MAX_HOURS × 60, or the reverse change would make max < min, then the update is rejected.
BR-SC-24	If ACCESS_REQUEST_SPONSOR_ALLOWED_AREA_TYPES is updated, then it must be a non-empty comma list containing only CONFIDENTIAL; PUBLIC, HIGHLY_CONFIDENTIAL and the retired INTERNAL_CONFIDENTIAL / CONFIDENTIAL_CONTACT_REQUIRED are rejected.
BR-SC-25	If a value is updated, then a change-log row (old → new, by, at, reason) is written and the new value takes effect without restart. The cache is updated inside the transaction and the old value is restored if the transaction does not commit.
BR-SC-26	If a key is missing in the cache or has the wrong type at read time, then a WARN is logged and the enum default is returned; a BOOLEAN that is not true/false returns the default (not false).
BR-SC-27	If EVENT_MODE_MAX_HOURS, EVENT_MODE_WINDOW_DAYS or EVENT_MODE_BUDGET_HOURS changes, then after commit areas whose active event or SCHEDULED schedules violate the new limits are listed to all active Facility Managers (EVENT_MODE_LIMIT_CHANGED); nothing is cancelled.
BR-SC-28	If AI_AFTER_HOUR_START or AI_AFTER_HOUR_END changes, then after commit the new window is pushed to the AI Service (POST /api/v1/system-config/after-hour); failure is only logged.
BR-SC-29	If the Administrator reloads, then the cache is rebuilt from the database (for values edited directly in the database).
BR-SC-30	If the backend starts, then it pushes the after-hours window and the AI runtime parameters (face match threshold, track inactivity, unknown-alert cooldown) to the AI Service; if the AI Service starts, then it pulls the same values from GET /api/internal/ai/runtime-config (protected by BR-CE-11) and retries until the backend answers. A failure is only logged; the AI Service then keeps its built-in defaults until the next push.
BR-SC-31	If REASON_MIN_LENGTH or REASON_MAX_LENGTH is updated, then 1 ≤ min < max ≤ 500 must hold (500 = the smallest database column that stores a reason); otherwise 400 with a message stating the current other value. If the stored pair is invalid (edited directly in the database), the validator logs a warning and uses 10/500. Every signed-in user can read the two values (GET /api/system-configurations/reason-limits); the rest of the configuration stays restricted.
BR-SC-32	If ACCESS_REQUEST_MAX_LEVEL_GAP is updated, then it must be an integer from 1 to 2; it is read at run time by the request rules (BR-RQ-27, BR-RQ-33, BR-TC-08).

9. Reason Catalog

ID	Rule Definition
BR-RC-20	If the caller is not an Administrator, then listing all reasons, creating, editing, deactivating and reactivating reasons are forbidden; the Facility Manager and the Administrator can read active reasons by action type.
BR-RC-21	If a reason is created, then action type must be one of EVENT_ENABLE, EVENT_DISABLE, EVENT_EXTEND, EVENT_SCHEDULE_CREATE, EVENT_SCHEDULE_UPDATE, EVENT_SCHEDULE_CANCEL; code ≤ 50 chars matching ^[A-Z0-9_]+$ (upper-case only: a code containing lower-case letters is rejected with 400, it is not converted); label ≤ 255 chars.

ID	Rule Definition
BR-RC-22	If the (action type, code) pair already exists, then creation is rejected; only one "Other" item is allowed per action type.
BR-RC-23	If a reason is edited, then only label and sort order can change (code and action type are immutable); an unchanged edit is not saved or audited.
BR-RC-24	If the "Other" item is deactivated, then it is rejected (ERR_AREA_029); deactivating an already inactive item is a no-op.
BR-RC-25	If a reason is created, edited, deactivated or reactivated, then an audit record (REASON_CATALOG) is written.
BR-RC-26	If an inactive reason (or one from another action group) is used in event mode or schedule operations, then it is rejected (BR-EV-A2, BR-ES-L2).

10. In-app Notification

ID	Rule Definition
BR-NT-20	If an authenticated user reads notifications, then only their own are returned (paged), with an unread count; marking read requires being the recipient (403 otherwise); mark-all affects only their own.
BR-NT-21	If notifications are created, then they are written in a separate transaction (REQUIRES_NEW) in one batch, so a notification failure never rolls back the business action.
BR-NT-22	If an APPROVED request starts within (lead − 5, lead + 5) minutes and no EXPIRING_SOON notification exists for it, then the requester and members receive EXPIRING_SOON (scan every 10 minutes).
BR-NT-23	If a request has been PENDING longer than the overdue hours and no PENDING_OVERDUE notification exists for it, then all active Facility Managers receive PENDING_OVERDUE (scan hourly).
BR-NT-24	If a notification for the same reference and type already exists, then the scans do not create it again.
BR-NT-25	If the web client shows the unread badge on the bell, then it polls the unread count every 60 seconds (no WebSocket or push). Exception: a Facility Manager also receives INCIDENT_ESCALATED in real time and the badge is refreshed at once (section 12).
BR-NT-26	If a notification about an access request or a guest visit is created for an Administrator, then it is not stored, except GUEST_PHOTO_REQUIRED (the Administrator does not review requests, does not review or host guest visits, but attaches guest photos). The filter is applied inside notification creation, so every sender follows it. On the web client, an Administrator who opens an older notification of these kinds gets an information message and is not navigated.

11. Audit Log

ID	Rule Definition
BR-AL-25	If a user reads audit logs, then only the modules mapped to their role are returned (Administrator: Area, Access Control, Access Request, System, Guest, Security; Facility Manager: Area, Access Control, Access Request); requesting another module returns 403.
BR-AL-26	If an audit snapshot cannot be serialised, then the write fails (no empty snapshot is stored in place of real data), rolling back the business action.
BR-AL-27	If a system job performs an audited action, then the actor is SYSTEM with a source name (e.g. EXPIRE_OVERDUE_REQUESTS_JOB, EVENT_MODE_EXPIRY, EVENT_SCHEDULE_ACTIVATION, AREA_TYPE_CHANGE, AREA_DEACTIVATION, REQUESTER_DEACTIVATION, GUEST_VISIT_JOB).
BR-AL-31	If a user reads audit logs of module SECURITY (viewing face or incident-evidence images, BR-MD-05), then only the Administrator is allowed; every other role receives 403 (V81_1, merged PR #102). (Renumbered from a duplicate BR-AL-28 on 2026-10-20.)

12. Incident Escalation

ID	Rule Definition
BR-IE-01	If a security incident is created, then it is sent immediately to the personal alert channel of every on-duty guard (BR-IE-02); the building channel and the global security-alert channel are sent as before. Guard location is not tracked (the guard GPS / geofence feature was removed; V85 deletes stored guard locations).
BR-IE-02	If a guard's account is active and not deleted, and one of the guard's shifts has status CHECKED_IN and the incident's detection time (Asia/Ho_Chi_Minh) lies within that shift's [start, end) window

ID	Rule Definition
	— a shift whose end time is earlier than its start time ends on the next day — then the guard is on duty. Only shifts dated today or yesterday are considered; a CHECKED_IN shift whose window has passed (shift not checked out) does not count. A guard with several matching shifts is alerted once.
BR-IE-03	If a security incident is created, then exactly one escalation record is created in the same transaction, storing the time and the number of guards alerted; only guards whose message was actually sent are counted; if the on-duty lookup fails, the record is still created with zero guards. If saving the record itself fails, only an error is logged and that incident is never escalated; incidents created before this feature have no record either. (Known limitation.)
BR-IE-04	If an incident is still NEW and the current time is at or after its creation time + INCIDENT_ESCALATE_FM_MINUTES, then every active Facility Manager receives an INCIDENT_ESCALATED in-app notification ("Security incident not yet claimed", with incident type, area, building, creation time, minutes waited and the instruction to contact guards by radio or phone) and a real-time message on /topic/escalations/facility-managers; the escalation record stores the escalation time and the number of Facility Managers notified, and is closed.
BR-IE-05	If no guard was alerted when the incident was created, then the Facility Manager escalation happens at the next check run without waiting for INCIDENT_ESCALATE_FM_MINUTES, and the message states that no guard was on duty.
BR-IE-06	If an incident leaves status NEW before it is escalated, then its escalation record is closed with reason CLAIMED, RESOLVED (RESOLVED_VERIFIED) or DISMISSED (RESOLVED_DISMISSED) and no Facility Manager is notified. A claimed incident cannot return to NEW (no "unclaim"; decision 2026-10-17).
BR-IE-07	If several check runs process the same incident, then Facility Managers are notified at most once: only the run whose conditional update (closed_at IS NULL) changes the record sends notifications, and an INCIDENT_ESCALATED notification that already exists for the incident is not created again. Each record is processed in its own transaction; a failure on one incident does not stop the others.
BR-IE-08	If the Administrator changes INCIDENT_ESCALATE_FM_MINUTES, then the new value applies from the next check run to every open escalation (the deadline is recomputed from the incident creation time); no restart is needed.
BR-IE-09	If a check run finishes, then the next run is scheduled INCIDENT_ESCALATION_CHECK_SECONDS later, the value being read before each scheduling; a value that is not positive (edited directly in the database) is replaced by the default 30 and a warning is logged.
BR-IE-10	If an incident is escalated, then the Administrator is never an escalation recipient; the chain ends at the Facility Manager. If an incident is due for escalation and no Facility Manager is active, then the escalation record stays open and is retried at every check run until a Facility Manager is active, who is then notified as usual (BR-IE-04); in addition, every active Administrator receives one INCIDENT_ESCALATION_NO_FM notification per incident, guarded by a conditional update (admin_no_fm_notified_at IS NULL) so later or concurrent runs never repeat it. Contacting the guards after the escalation is done outside the system (radio or phone).
BR-IE-11	If an escalation notification names the incident type, then INTRUSION and AFTER_HOURS_* are shown as "After-hours intrusion", UNAUTHORIZED_ACCESS / UNAUTHORIZED as "Unauthorized intrusion", UNKNOWN_PERSON / UNKNOWN as "Unverified stranger"; any other type is shown by its code. (Notification texts are written in code, not in a configurable template — see Open points.)

13. Guard Mobile Alerts

ID	Rule Definition
BR-GN-01	If the logged-in guard has a CHECKED_IN shift in the loaded shift list, then the app starts a foreground service with a silent, persistent notification "On duty" and connects to the real-time channel without waiting for the map screen; if no shift is CHECKED_IN any more, then the service is stopped. The service keeps Android from freezing the app in the background so incident alerts keep arriving.
BR-GN-02	If the app receives a new incident while a user is logged in, then it shows a high-priority system notification "New security incident" with incident type, area and local time, whether the app is in the foreground or in the background; the notification contains no person name, code or image, and its content is hidden on a secured lock screen.

ID	Rule Definition
BR-GN-03	If the same incident is received again, then no second notification is shown; if the incident is claimed or resolved, then its notification is removed.
BR-GN-04	If the guard taps an incident notification, then the app opens the patrol map, which lists the pending incidents.
BR-GN-05	If the guard logs out, then the foreground service is stopped, the real-time connection is closed and all notifications are removed.

14. Image Access (face, evidence, camera snapshots)

ID	Rule Definition
BR-MD-01	If a client requests an image through GET /api/media/{bucket}/{object} without a valid login token, then the request is rejected with 401.
BR-MD-02	If the caller's role is not allowed for the bucket, then the request is rejected with 403 before the object is looked up, so the response never reveals whether an image exists. Allowed roles: face-profiles → Administrator; camera-snapshots → Administrator; security-evidence → Administrator, Guard, Facility Manager. Any other bucket → 403 for everyone.
BR-MD-03	If the object path is empty, longer than 100 characters, contains "..", starts with "/" or contains control characters, then the request is rejected with 400.
BR-MD-04	If the object does not exist, then 404 is returned without storage details; any other storage error returns 500 without storage details.
BR-MD-05	If an allowed user views an image of face-profiles or security-evidence, then an audit record VIEW_PHOTO is written (target FACE_PROFILE with the user code taken from the path, or SECURITY_EVIDENCE with the object path; actor = viewer) before the image is returned; if the audit record cannot be written, then the image is not returned (500). Viewing camera-snapshots is not audited.
BR-MD-06	If an image is returned, then the response carries Cache-Control: private, no-store and X-Content-Type-Options: nosniff, and the content type comes from the storage metadata.
BR-MD-07	If the backend starts, then any access policy on the three buckets is removed, so an image can never be opened directly from MinIO without credentials; a failure to remove it is only logged as a warning.

15. Security Dashboard

ID	Rule Definition
BR-DB-01	If security statistics are requested, then the period is one of TODAY, LAST_7_DAYS (default) or LAST_30_DAYS; a period of N days starts at 00:00 Asia/Ho_Chi_Minh on the (N − 1)th day before today and ends at the time of the request, both ends included. Any other value is rejected (400).
BR-DB-02	If incidents are counted, then they are counted by detection time within the period for each status NEW, CLAIMED, RESOLVED_VERIFIED and RESOLVED_DISMISSED; a status without incidents is reported as 0.
BR-DB-03	If the dismissed rate is computed, then it is RESOLVED_DISMISSED / (RESOLVED_VERIFIED + RESOLVED_DISMISSED) over incidents detected in the period; NEW and CLAIMED incidents are excluded; with no concluded incident the rate is undefined and shown as "—". (The screen labels it "false-alarm rate"; a dismissal is a Security Officer's rejection of the alert, which also covers authorized exceptions.)
BR-DB-04	If the top areas are listed, then at most five areas with the most incidents in the period are shown in descending order of count, ties ordered by area name.
BR-DB-05	If access attempts are charted, then they are counted per calendar day in Asia/Ho_Chi_Minh by access result (5 results); every day of the period appears, with 0 for days without attempts.
BR-DB-06	If a user other than a Facility Manager or an Administrator requests security statistics, then the request is rejected (403) and the Dashboard section is not shown. The statistics are read-only.

5.2 Common Requirements

ID	Requirement
CR-01	Every business parameter (limits, lead times, retention periods, AI after-hours window and runtime parameters, reason lengths) is stored in System Configuration with a data type and an allowed range; a change made on the System Configuration screen takes effect from the next request without restart and is recorded with its reason.

ID	Requirement
CR-02	Every change of business data writes one append-only audit record with actor, target, old and new values and reason; scheduled jobs write records with actor System.
CR-03	Every reason entered by a user is trimmed and checked against REASON_MIN_LENGTH and REASON_MAX_LENGTH by one shared validator.
CR-04	Records that two users can change at the same time are protected by a version number or by a conditional update; the losing call returns 409 with a message that states the current state, and the web client reloads the data.
CR-05	All times are stored with time zone and evaluated in Asia/Ho_Chi_Minh; time windows are half-open [start, end).
CR-06	Notifications are sent only after the business transaction commits; a failed notification never rolls back the business change.
CR-07	Error responses use one body format { timestamp, httpCode, message, errorCode, code, status }; the web client shows message (5.3).
CR-08	Accounts and areas are soft-deleted; deactivating or deleting an account cancels the user's active requests and revokes the user's assignments.

5.3 Application Messages List

Messages of the access-control part. Codes ERR_* are returned by the backend; MSG-* are assigned for this document. Content is the English translation of the Vietnamese text shown to users. {x} is a value inserted at run time.

#	Message code	Message Type	Context	Content
1	ERR_AC_003	Error (409)	Area Type Defaults — toast	The configuration was changed by someone else. Please reload and try again.
2	ERR_AC_004	Error (404)	Area Type Defaults — toast	No default configuration exists for this area type.
3	ERR_AC_005	Error (400)	(API only; the Area Type Defaults screen is removed)	The area access level is fixed by the area type (Public: level 1, Confidential: level 2, Highly Confidential: level 3) and cannot be changed.
4	ERR_AC_006	Error (403)	Request Approval (Access requests tab) — banner (BR-RQ-06)	You cannot approve or reject an access request you created.
5	ERR_AC_007	Error (400)	Request Approval (Access requests tab), Finish Request popup — inline (BR-RQ-46)	The request has not reached its start time ({startTime}) and cannot be finished yet.
6	ERR_AC_008	Error (400)	Request Approval (Access requests tab), Cancel Approved Request popup — inline (BR-RQ-47)	The request already started ({startTime}) and cannot be cancelled; use Finish.
7	ERR_AC_009	Error (409)	User Access Levels — toast; bulk change popup — per-user result (BR-AL-29)	The account {userCode} is deactivated, so its access level cannot be changed.
8	ERR_AC_011	Error (409)	User Access Levels — toast / change-level popup; bulk change popup — per-user result (BR-AL-30)	User {userCode} – {fullName} has {count} pending access request(s) ({areas}). Approve or reject them before changing the access level.
9	ERR_AC_010	Error (400)	Access History (my history and all) — empty state (BR-AH-04)	The start time ({from}) must be before or equal to the end time ({to}).
10	ERR_AC_012	Error (409)	Request Approval, "Access requests" tab, Approve / Reject popup — warning banner (BR-RQ-48)	The start time has passed, so the request can no longer be approved or rejected. The system will mark it as Expired.
11	ERR_AREA_002	Error (404)	Area Management popup — inline	Area not found.
12	ERR_AREA_003	Error (400)	Area Management popup — inline	The area type is invalid or no longer in use.

#	Message code	Message Type	Context	Content
13	ERR_AREA_005	Error (400)	Area Management, Create / Edit Area popup — inline (also checked by the web client) (BR-AR-02)	Area name is required and must be 3–100 characters.
14	ERR_AREA_006	Error (400)	Area Management, Create / Edit Area popup — inline under the empty field	Enter both latitude and longitude, or leave both empty.
15	ERR_AREA_009	Error (409)	Area Management, Deactivate Area popup — inline (BR-AD-06)	Cannot deactivate: {n} camera(s) are still assigned. Remove them first.
16	ERR_AREA_017	Error (400)	Area Management — toast or inline	The area is inactive or has been deleted.
17	ERR_AREA_018	Error (400)	Area Management, Create / Edit Area popup — inline (BR-AR-03)	The area name must contain at least one letter.
18	ERR_AREA_019	Error (400)	Area Management, Create / Edit Area popup — inline (BR-AR-04)	The area name may contain only letters, digits, spaces and - _ ( ) . , /
19	ERR_AREA_020	Error (409)	Area Management, Create / Edit / Restore Area popup — inline (BR-AR-05)	An area with this name already exists on this floor.
20	ERR_AREA_021	Error (400)	Area Management popup — inline	The floor is invalid or was not found.
21	ERR_AREA_022	Error (400)	Area Management, event mode / schedule popups — toast	Event mode applies only to Confidential areas.
22	ERR_AREA_024	Error (400)	Event Management, Create / Edit / Cancel Event and Stop Event popups — inline or toast	The note must have 10–500 characters.
23	ERR_AREA_025	Error (400)	Area Management, Area Access Rules popup (event mode) — toast	The reason code does not exist or is inactive.
24	ERR_AREA_026	Error (400)	Area Management, Area Access Rules popup (event mode) — toast	The reason code does not match this event action.
25	ERR_AREA_028	Error (400)	Area Management, Area Access Rules popup (event mode) — toast	The area's event-time budget would be exceeded (used / remaining / requested hours).
26	ERR_AREA_029	Error (400)	Reason Catalog — banner	The default "Other" reason cannot be deactivated.
27	ERR_AREA_030	Error (409)	Area Management, Area Access Rules popup — toast, data reloaded (BR-EV-A3/A5)	The event status has changed: {status}. Please reload.
28	ERR_AREA_032	Error (400)	Area Management, Event Schedules section — toast	The schedule start time must be in the future.
29	ERR_AREA_033	Error (400)	Area Management, Event Schedules section — toast	The start time is beyond the maximum booking lead time ({maxLeadDays} days).
30	ERR_AREA_034	Error (400)	Area Management, Event Schedules section — toast	The schedule end time must be after its start time.
31	ERR_AREA_035	Error (400)	Area Management, Event Schedules section — toast	The schedule must last at least {minMinutes} minutes.
32	ERR_AREA_036	Error (400)	Area Management, Event Schedules section — toast	The schedule exceeds the maximum session length ({maxHours} hours).
33	ERR_AREA_037	Error (409)	Area Management, Event Schedules section — toast	The schedule overlaps another scheduled event.
34	ERR_AREA_038	Error (409)	Area Management, Event Schedules section — toast	The schedule overlaps the active event session.
35	ERR_AREA_039	Error (400)	Area Management, Event Schedules section — toast	The area already has the maximum number of upcoming schedules ({maxSchedules}).
36	ERR_AREA_040	Error (409)	Area Management, Event Schedules section — toast	Only upcoming (SCHEDULED) schedules can be edited or cancelled.

#	Message code	Message Type	Context	Content
37	ERR_AREA_042	Error (409)	Area Management, Area Type Change Preview / Deactivate Area popup — inline	The area has {count} upcoming event schedule(s); cancel them first.
38	ERR_AREA_043	Error (404)	Area Management, Event Schedules section — toast	Event schedule not found.
39	ERR_AREA_044	Error (400)	Area Management popups — inline or toast (BR-TC-13)	The area version is missing; please reload the page.
40	ERR_AREA_045	Error (409)	Area Management popups — inline, data reloaded (the web client replaces the text, see FE-AR-02)	The area was updated by someone else; please reload.
41	ERR_AREA_046	Error (400)	Not shown (API integration error) (BR-EV-A1)	The enabled field is no longer supported; send action DISABLE.
42	ERR_AREA_047	Error (400)	Not shown (API integration error) (BR-EV-A1)	The event-mode action is missing (only DISABLE is supported).
43	ERR_AREA_048	Error (409)	Area Management, Edit Area popup and Area Type Change Preview — inline (BR-TC-05)	The area is in event mode and cannot change to {newType}; disable the event first.
44	ERR_AREA_049	Error (409)	Area Management, Edit Area popup and Area Type Change Preview — inline (BR-TC-07)	The area has {count} active personnel assignment(s); revoke them before making it Public.
45	ERR_AREA_050	Error (400)	Area Management, Edit Area popup — inline (BR-TC-02)	The reason must be 10–500 characters.
46	ERR_AREA_051	Error (409)	Area Management popup — inline (BR-AD-02)	The area has {count} unresolved incident(s); resolve them before deactivating.
47	ERR_AREA_052	Error (409)	Area Management popup — inline (BR-AD-03)	The area is in event mode; disable it before deactivating.
48	ERR_AREA_053	Error (409)	Area Management, Deactivate Area popup — inline (BR-AD-01)	The area is already deactivated.
49	ERR_AREA_054	Error (409)	Area Management, Restore Area popup — inline (BR-AD-07)	The area is not deactivated; nothing to restore.
50	ERR_AREA_055	Error (409)	Area Management, Restore Area popup — inline (BR-AD-07)	Cannot restore: the area's floor or building is inactive.
51	ERR_AREA_056	Error (400)	(API only; the access-rules action is removed from Area Management)	The area access level is fixed by the area type (Public: level 1, Confidential: level 2, Highly Confidential: level 3); to change it, change the area type.
52	ERR_AREA_057	Error (400)	Event Management, Create / Edit Event popup — inline	The event name is required, with at most 150 characters.
53	ERR_AREA_058	Error (400)	API only; the web client sends DISABLE only (BR-EV-A7)	Event mode cannot be enabled or adjusted manually. Book a schedule on Event Management.
54	ERR_AP_001	Error (404)	Area Management, Assigned Personnel popup — toast	The assignment was not found in this area.
55	ERR_AP_002	Error (400)	Area Management, Assigned Personnel popup — toast	The end time must be after the start time.
56	ERR_AP_003	Error (400)	Area Management, Assigned Personnel popup — toast	The end time must be in the future. To end it now, revoke the assignment.
57	ERR_AP_004	Error (409)	Area Management, Assigned Personnel popup — toast	The user already has an overlapping assignment in this area.
58	ERR_AP_005	Error (404)	Area Management, Assigned Personnel popup — toast	User not found.
59	ERR_AP_006	Error (400)	Area Management, Assigned Personnel popup — toast	A deactivated or deleted user cannot be assigned.
60	ERR_AP_007	Error (400)	Area Management, Assigned Personnel popup — toast	Cannot assign to an inactive or deleted area.
61	ERR_AP_008	Error (400)	Area Management, Assigned Personnel popup — toast	A revocation reason is required.

#	Message code	Message Type	Context	Content
62	ERR_AP_009	Error (409)	Area Management, Assigned Personnel popup — toast	The assignment has been revoked and can no longer be changed.
63	ERR_AP_010	Error (400)	Area Management, Assigned Personnel popup — toast	Personnel assignment does not apply to Public areas.
64	ERR_AP_011	Error (403)	Area Management, Assigned Personnel popup — toast (BR-AP-06)	You cannot assign yourself. Ask another facility manager.
65	ERR_AP_012	Error (409)	Area Management, Assigned Personnel popup — toast; API only, the Revoke button is hidden on Expired rows (BR-AP-30)	The assignment has already expired and does not need revoking. To grant again, create a new assignment.
66	ERR_AP_013	Error (400)	Area Management, Assigned Personnel popup — toast; the form blocks it first with the same text (BR-AP-28)	The start time cannot be in the past.
67	ERR_GUEST_001	Error (404)	My Guest Visits / Request Approval (Guest visits tab) / Guest Photos — inline	Guest visit not found.
68	ERR_GUEST_002	Error (403)	My Guest Visits, Create guest visit popup — inline	Your account is not eligible to invite guests (must be active with access level {n} or higher).
69	ERR_GUEST_003	Error (400)	My Guest Visits, Create guest visit popup — inline	A visit must have 1 to {n} guests.
70	ERR_GUEST_004	Error (400)	My Guest Visits, Create guest visit popup — inline	Guest name must be 2–100 characters.
71	ERR_GUEST_005	Error (400)	My Guest Visits, Create guest visit popup — inline	Guest organisation must be at most 200 characters.
72	ERR_GUEST_006	Error (400)	My Guest Visits, Create guest visit popup — inline	The purpose must be 10–500 characters.
73	ERR_GUEST_007	Error (400)	My Guest Visits, Create guest visit popup — inline	Select at least one area, without duplicates.
74	ERR_GUEST_008	Error (400)	My Guest Visits, Create guest visit popup — inline	Area {name} does not exist or is inactive.
75	ERR_GUEST_009	Error (400)	My Guest Visits, Create guest visit popup — inline	Area {name} does not accept guests (Confidential areas only).
76	ERR_GUEST_010	Error (400)	My Guest Visits, Create guest visit popup — inline	The start time must be in the future.
77	ERR_GUEST_011	Error (400)	My Guest Visits, Create guest visit popup — inline	The end time must be after the start time.
78	ERR_GUEST_012	Error (400)	My Guest Visits, Create guest visit popup — inline	A visit can last at most {n} hours.
79	ERR_GUEST_013	Error (400)	My Guest Visits, Create guest visit popup — inline	A visit can be booked at most {n} days in advance.
80	ERR_GUEST_014	Error (403)	My Guest Visits, Create guest visit popup — inline	The host is not allowed into {name} for the whole visit window (only access level or personnel assignment counts).
81	ERR_GUEST_015	Error (400)	My Guest Visits (cancel) / Request Approval (Guest visits tab) (review, revoke) — inline	The visit version is missing.
82	ERR_GUEST_016	Error (409)	My Guest Visits (cancel) / Request Approval (Guest visits tab) (review, revoke) — inline	The visit was updated by someone else; please reload.
83	ERR_GUEST_017	Error (409)	My Guest Visits (cancel) / Request Approval (Guest visits tab) (review, revoke) — inline	The visit is {status} and cannot be {action}.
84	ERR_GUEST_018	Error (409)	My Guest Visits (cancel) / Request Approval (Guest visits tab) (review, revoke) — inline	The visit has ended and cannot be {action}.

#	Message code	Message Type	Context	Content
85	ERR_GUEST_019	Error (400)	My Guest Visits (cancel) / Request Approval (Guest visits tab) (review, revoke) — inline	The reason must be 10–500 characters.
86	ERR_GUEST_020	Error (400)	My Guest Visits, Create guest visit popup — inline	Required field missing: {field}.
87	ERR_GUEST_021	Error (409)	Request Approval (Guest visits tab) — inline	The visit no longer meets the approval conditions: {reason}.
88	ERR_GUEST_022	Error (403)	Request Approval (Guest visits tab) — inline	You cannot approve, reject or revoke a visit you host.
89	ERR_GUEST_023	Error (409)	Request Approval (Guest visits tab) — inline	The start time has passed; the visit can no longer be approved.
90	ERR_GUEST_024	Error (400)	Request Approval (Guest visits tab) — inline	The decision must be APPROVED or REJECTED.
91	ERR_GUEST_025	Error (400)	My Guest Visits, Create guest visit popup — inline (BR-GV-02)	Field {field} is not part of the visit form (ID number, phone, address and email are not accepted).
92	ERR_GUEST_030	Error (409)	Guest Photos, Attach / View guest photo popup — inline	Photos can be attached only to guests of an approved, ongoing visit.
93	ERR_GUEST_031	Error (400)	Guest Photos, Attach / View guest photo popup — inline	Confirm the guest's consent to notice version {version}.
94	ERR_GUEST_032	Error (404)	Guest Photos, Attach / View guest photo popup — inline	Guest not found in this visit.
95	ERR_GUEST_033	Error (400)	Guest Photos, Attach / View guest photo popup — inline	The photo must be JPG or PNG, at most {n} KB.
96	ERR_GUEST_034	Error (400)	Guest Photos, Attach / View guest photo popup — inline	The photo must contain exactly one face ({n} detected).
97	ERR_GUEST_035	Error (503)	Guest Photos, Attach / View guest photo popup — inline	The AI service could not extract the face; please try again later.
98	ERR_GUEST_036	Error (503)	Guest Photos, Attach / View guest photo popup — inline	Guest photo storage is temporarily unavailable; please try again later.
99	ERR_GUEST_037	Error (404)	Guest Photos, Attach / View guest photo popup — inline	The guest has no photo or it was deleted.
100	ERR_CAM_002	Error (404)	Area Management, Area Cameras popup — toast	Camera not found.
101	ERR_MAP_002	Error (400)	Area Management, Area Cameras popup — toast	A decommissioned camera cannot be assigned.
102	MSG-RQ-01	Error (400)	Access Requests, new request form — inline	Public areas do not require an access request.
103	MSG-RQ-02	Error (400)	Access Requests, new request form — inline	The start time must be before the end time.
104	MSG-RQ-03	Error (400)	Access Requests, new request form — inline	The start time cannot be in the past.
105	MSG-RQ-04	Error (400)	Access Requests, new request form — inline	The start time cannot be more than {maxAdvanceDays} days ahead (you chose {n}).
106	MSG-RQ-05	Error (400)	Access Requests, new request form — inline	Access cannot last more than {maxDurationHours} hours (you entered {n}).
107	MSG-RQ-06	Error (400)	Access Requests, new request form — inline	The requester's access level is too low for this area (Level {n} required): {name} ({code}).
108	MSG-RQ-07	Error (400)	Access Requests, new request form — inline	Highly Confidential areas accept individual requests only.
109	MSG-RQ-08	Error (400)	Access Requests, new request form — inline	Some members' access level is too low (Level {n} required): {list}.
110	MSG-RQ-09	Error (400)	Access Requests, new request form — inline	A group request needs a member list.
111	MSG-RQ-10	Error (400)	Access Requests, new request form — inline	A group request needs at least one member besides the requester.

#	Message code	Message Type	Context	Content
112	MSG-RQ-11	Error (400)	Access Requests, new request form — inline	A group can have at most {max} members besides the requester (you chose {n}).
113	MSG-RQ-12	Error (400)	Access Requests — inline under the member codes	{code}: no eligible user found with this code.
114	MSG-RQ-13	Error (409)	Access Requests, new request form — inline	The request overlaps another request in this area for: {code - name, …}.
115	MSG-RQ-14	Error (400)	Access Requests — inline	The user code list cannot be empty.
116	MSG-RQ-15	Error (400)	Access Requests — inline	You can look up at most {max} codes.
117	MSG-RQ-16	Error (400)	Access Requests — suggestion list is hidden	The search code may contain only letters, digits or hyphens, 1–20 characters.
118	MSG-RQ-17	Error (429)	Access Requests — inline under the member codes (the web client shows its own text)	You are looking up too fast; please try again in a few minutes.
119	MSG-RQ-18	Error (400)	Request Approval (Access requests tab) — banner	The review status must be APPROVED or REJECTED.
120	MSG-RQ-19	Error (400)	Request Approval (Access requests tab), Reject Request popup — inline (also checked by the web client)	Please give a rejection reason / The rejection reason must be 10–500 characters.
121	MSG-RQ-20	Error (400)	Request Approval (Access requests tab) — banner	Group requests cannot be approved for Highly Confidential areas.
122	MSG-RQ-21	Error (400)	Request Approval (Access requests tab) — banner	The requester no longer has the required access level (Level {n}): {name} ({code}).
123	MSG-RQ-22	Error (400)	Request Approval (Access requests tab) — banner	Member {code} has been deactivated or removed.
124	MSG-RQ-23	Error (409)	Request Approval (Access requests tab) — warning banner for 7 seconds, list reloaded	This request was just {approved/rejected} by {reviewer} at {time}. The list has been refreshed.
125	MSG-RQ-24	Error (409)	Request Approval (Access requests tab) — banner	This request was cancelled by its creator / has expired / is already {status} and cannot be approved.
126	MSG-RQ-25	Error (403)	Access Requests — banner	Access denied: you cannot cancel this access request.
127	MSG-RQ-26	Error (409)	Access Requests — warning banner for 7 seconds, list reloaded	This request has expired / was just {approved/rejected} by {reviewer} and cannot be cancelled.
128	MSG-RQ-27	Error (403)	Not shown (no screen calls this endpoint)	Access denied: you cannot view this access request.
129	MSG-RQ-28	Error (400 / 403)	Request Approval (Access requests tab), Finish Request popup (BR-RQ-46)	Only APPROVED requests can be marked finished. / You cannot mark this request finished.
130	MSG-RQ-29	Error (404)	Access Requests, new request form — inline	The area does not exist or has been deactivated.
131	MSG-AL-01	Error (403)	User Access Levels — toast	Access denied: you cannot change your own access level.
132	MSG-AL-02	Removed	— (the keyword is optional since BR-AL-23 was changed; the message no longer exists in code)	The search keyword must be at least 2 characters.
133	MSG-AU-01	Error (409)	Account Management, Create Account popup — inline	The user code / email already exists.
134	MSG-AU-02	Error (400)	Account Management, Create Account popup — inline	Invalid role. Allowed: FACILITY_MANAGER, GUARD, NORMAL_USER. / The system allows only one Administrator; another Administrator account cannot be created.

#	Message code	Message Type	Context	Content
135	MSG-AU-03	Error (400)	Account Management — confirmation popup	You cannot deactivate / delete your own account.
136	MSG-AU-04	Error (400)	Account Management, Bulk Import popup	The file has {n} records, exceeding the maximum of {max}.
137	MSG-AU-05	Error (400)	Account Management, Bulk Import popup	Please choose a ZIP file / Only .zip is accepted / metadata.xlsx or metadata.csv not found / required columns missing.
138	MSG-AU-06	Error (row result)	Account Management, Bulk Import popup — per-row result table	Per-row import errors: user code empty / longer than 50 characters / already exists; full name invalid; e-mail invalid / already exists; user code or e-mail duplicated in the import file; image file not found; image larger than 350 KB; staff role not allowed in the Authorized User import.
139	MSG-AU-07	Error (401)	Login — inline	Invalid email or password / Email is not authorized or account is disabled / Email not found or account is deactivated (shown in English as returned) / The password reset token is invalid / has already been used / has expired.
140	MSG-AU-08	Success (200)	Login, Forgot Password popup — success box	If the e-mail exists in the system, you will receive password reset instructions by e-mail. (same response for every e-mail, BR-AU-33)
141	MSG-SC-01	Error (400)	System Configuration — banner	Configuration value errors (empty, not editable, out of range, not boolean, too long, bad HH:mm).
142	MSG-SC-02	Error (400)	System Configuration — banner	Minimum event duration cannot exceed the maximum (and vice versa).
143	MSG-SC-03	Error (400)	System Configuration — banner	The sponsor-allowed area type list cannot be empty and cannot include Public or Highly Confidential.
144	MSG-RC-01	Error (400)	Reason Catalog — banner	Reason code '{code}' already exists for {type} / An "Other" item already exists for {type}.
145	MSG-NT-01	Error (403)	Not shown on a screen	Access denied: you cannot access this notification.
146	MSG-AD-01	Error (403)	Audit Log — toast (the web client shows its own text)	Access denied: you cannot read audit logs of module {module}.
147	VALIDATION_ERROR	Error (400)	All screens	The input data is invalid. (The response also lists each invalid field with its message.)
148	VALIDATION_ERROR (centerLatitude / centerLongitude)	Error (400)	Area Management, Create / Edit Area popup — returned per field in data; the web form checks the range first (FE-AR-01) (BR-AR-23)	Latitude must be between -90 and 90. / Longitude must be between -180 and 180.
149	NOT_FOUND	Error (404)	All screens	The requested path was not found.
150	(HTTP reason phrase)	Error (by exception)	All screens	The exception message is returned as written; the error code is the HTTP reason phrase ("Bad Request", "Conflict", …), with no business code.
151	Forbidden	Error (403)	All screens	Access denied: …
152	PAYLOAD_TOO_LARGE	Error (413)	All screens	The uploaded file exceeds the maximum allowed size (500 MB).
153	Conflict	Error (409)	All screens	The data duplicates existing records or violates an integrity constraint.

#	Message code	Message Type	Context	Content
154	ERR_AUDIT_001	Error (500)	All screens (BR-AL-26)	The audit record could not be written; the action was not performed. Please retry.
155	Internal Server Error	Error (500)	All screens	System error. Reference: {errorId}.
156	MSG-OK-01	Success	My Guest Visits — toast / banner	Guest visit created and pending approval.
157	MSG-OK-02	Success	Account Management — banner	Account created. The initial password was emailed.
158	MSG-OK-03	Success	Account Management — confirmation popup	{n} accounts removed from the batch.
159	MSG-OK-04	Success	Request Approval (Access requests tab) — banner (BR-RQ-46)	Request moved to Finished.
160	FE-RQ-01	Validation (web client)	Access Requests, new request form — inline	Please select an area.
161	FE-RQ-02	Validation (web client)	Access Requests, new request form — inline	Please choose the date and time range.
162	FE-RQ-03	Validation (web client)	Access Requests, new request form — inline	The end time must be after the start time.
163	FE-RQ-04	Removed	— (the web client no longer checks the past start time; the backend message for BR-RQ-23 is shown)	The start time cannot be in the past.
164	FE-RQ-05	Validation (web client)	Access Requests, new request form — inline	A group request needs at least one member / one member besides you.
165	FE-RQ-06	Validation (web client)	Access Requests, new request form — inline	Please enter the purpose.
166	FE-RQ-07	Validation (web client)	Request Approval (Access requests tab), Reject Request popup — inline (BR-RQ-39)	The reason must be 10–500 characters (currently {n}).
167	FE-RQ-08	Validation (web client)	Access Requests — row in the member code suggestion list	No matching code.
168	FE-AR-01	Validation (web client)	Area Management, Create / Edit Area popup — inline under the empty field	Enter both coordinates or neither / Latitude must be −90..90 / Longitude must be −180..180.
169	FE-AR-02	Validation (web client)	Area Management, Edit Area popup — inline (replaces ERR_AREA_045)	The area was updated by someone else. Close and reopen to see the latest data.
170	FE-GV-01	Validation (web client)	My Guest Visits, cancel popup — inline (replaces ERR_GUEST_016)	The visit was updated by someone else. The list was reloaded; please check and retry.
171	FE-AP-01	Validation (web client)	Area Management, Assigned Personnel popup — toast	Please select the user to assign.
173	FE-SYS-01	Information (web client)	Any screen — toast or banner, depending on the screen	Cannot reach the server. Check your network or the backend.

5.4 Other Requirements…

5.4.1 Legal and Compliance (personal and biometric data)

ID	Requirement	Status
LC-01	Face images of students and staff are biometric personal data. Their collection needs a legal basis and a notice to the data subjects; guests give explicit consent before their photo is attached, and the consent notice version is recorded with the guest.	Guest consent: implemented. Notice for students and staff: [to be agreed with the campus administration]
LC-02	Data minimisation: the system stores only user code, full name, e-mail, role, access level and face data; it does not store ID card numbers, phone numbers or home addresses.	Implemented

ID	Requirement	Status
LC-03	Retention: guest biometric data is deleted after the configured retention period and old guest records are anonymised by the guest visit job; camera access logs are deleted after ENTRY_LOG_RETENTION_DAYS.	Implemented (NSF-06, NSF-19)
LC-04	Face data of users who have left the university (deleted or deactivated accounts) is deleted after a configured period.	Not implemented — planned
LC-05	Access to images and video: only the roles listed in 3.1.3 can view them; viewing a guest photo is audited; files are never served by direct link.	Implemented for images; video access: [to be completed by the camera owner]
LC-06	Entering a user code never returns personal data to a caller who is not allowed to see it (no lookup oracle).	Implemented for member lookup (rate limited, eligible users only)
LC-07	No API key, password or secret is stored in the source code; secrets come from environment variables.	To be verified by a repository scan before submission
LC-08	Recorded video stored in Google Drive must stay private to the system account, be deleted after the retention period, and be played back only through the backend with permission checks and audit.	Planned — not implemented